FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud schemes, target control environment and implementation programme

58 of 106 applicable fraud schemes have a control reported as a gap.

55.5

CALCULATED FIGURE / 100

DEVELOPING

BAND OF THE CALCULATED FIGURE

A test fixture, not an approved score or readiness conclusion.

PREPARED FOR

Fictional Retail Group (mixed controls)

Assessment reference · FX-P3

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

HOW TO READ THIS REPORT

Contents

Management report	SECTIONS 1–9
1 · Where the organisation stands	
2 · What is driving the position	
3 · Where the material fraud exposure sits	
4 · Fraud scenario portfolio	
5 · The control environment management should build	
6 · Who must own the response	
7 · Decisions leadership must make	
8 · What should happen, and in what order	
9 · How management will know it is working	

Registers	APPENDICES A–I
A · Finding register	59 entries
B · Fraud risk register	58 entries
C · Control blueprint register	106 entries
D · Records management should maintain	47 entries
E · Action register	126 entries
F · Measurement register	106 entries
G · Answer relationships	1 entries
H · Outstanding information	0 entries
I · Roles used in this report	11 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report. The appendices hold every scheme, risk, control, record, action, measure, answer relationship and outstanding answer behind it, and the supporting workbook holds the same registers with the method references that trace each row to the question asked and the answer given.

BASIS OF THIS REPORT

This report is produced by fixed rules from the organisation's answers to the MK Fraud Readiness review, read against the draft review method, which MK has not yet approved. The AI manuscript stage has not been run; the interpretation in each section is fixed-rule text. No evidence has been examined, no control has been tested for operating effectiveness, no one has been interviewed and no assurance opinion is given. Records named in this report are records management should maintain; independent review of evidence is a separate Advisory service.

TEST FIXTURE

SECTION 1 · WHERE THE ORGANISATION STANDS

What the answers indicate

Each applicable fraud scheme, classified from the organisation's own answers. Nothing here has been tested or verified.

106
FRAUD SCHEMES THAT APPLY

48
CONTROLS THAT STOP THE SCHEME REPORTED IN PLACE

58
A CONTROL REPORTED AS A GAP

0
ANSWERS TO RESOLVE

0
ANSWERS OUTSTANDING

AREA	SCHEMES	IN PLACE	IN PLACE, FURTHER DEFENCE WEAKER	GAP	TO RESOLVE	NOT ANALYSED	CALCULATED FIGURE*
Third parties and supply chain	13	1	0	12	0	0	24.3
People, payroll and insider risk	11	0	0	11	0	0	26.4
Customers, revenue and products	10	0	0	10	0	0	25.0
Assets, cash and inventory	10	0	0	10	0	0	19.0
Digital, cyber-enabled and identity fraud	14	0	0	14	0	0	18.6
Ethics, integrity and anti-corruption	10	8	1	1	0	0	81.0
Fraud governance and accountability	12	12	0	0	0	0	90.0
Fraud risk assessment	6	6	0	0	0	0	91.7
Finance, banking and financial reporting	12	12	0	0	0	0	92.5
Detection, speak-up and response	8	8	0	0	0	0	86.7

* Calculated figure 55.5 / 100 (Developing). TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.

WHAT THIS MEANS

48 of the 106 schemes have the controls that stop them reported in place; in 1 of these a further defence is reported weaker, which does not change the answer given for the control. 58 have a control reported as a gap, 22 of them in tier 1, the schemes the draft method confirms in its core stage. The tier says how early the method asks about a scheme; it is not a rating of how serious it is. The core stage is complete and the breadth stage complete; 106 of the 106 schemes asked about can be analysed in full from the answers given.

SECTION 2 · WHAT IS DRIVING THE POSITION

The patterns behind the answers

Answers to resolve first, then requirements that span several areas, then where the gaps concentrate.

Requirements that span several areas

The method groups some controls into requirements that cross areas. Where two or more of them are reported as gaps in different areas, the weakness is connected: fixing one area leaves the route open through another.

REQUIREMENT	CONTROLS REPORTED AS GAPS	IN PLACE OF THOSE ASKED
Changes to payment details are verified through a route the requester does not control	Change confirmed with supplier (procurement: partly in place); Familiar caller still verified (procurement: not in place); Bank changes confirmed with employee (people: not in place); Customer detail changes verified (customers: partly in place); Changes to call-back details verified (digital channels: partly in place); Email never enough on its own (digital channels: not in place)	1 of 7
Identity is established through routes an impersonator cannot control	Identity verified (people: partly in place); Remote appointee identity confirmed (people: partly in place); Help desk resets verified (digital channels: partly in place); Verification for calls, voice notes and video (digital channels: partly in place); Familiar caller still verified (procurement: not in place)	0 of 5
Accounts are confirmed as belonging to the payee	Bank account verified (procurement: partly in place); Refunds to the original source (customers: not in place)	0 of 2
Independent assurance examines high-risk processes	Independent review of procurement (procurement: partly in place); Independent review of payroll (people: partly in place)	0 of 2

Where the gaps concentrate

AREA	SCHEMES WITH A GAP	OF WHICH TIER 1	SCHEMES IN THE AREA
Digital, cyber-enabled and identity fraud	14	5	14
Third parties and supply chain	12	6	13
People, payroll and insider risk	11	5	11
Customers, revenue and products	10	4	10
Assets, cash and inventory	10	2	10
Ethics, integrity and anti-corruption	1	0	10

The schemes themselves are listed by area in Section 3.

WHAT THIS MEANS

4 requirements span several areas with gaps in more than one, most widely: changes to payment details are verified through a route the requester does not control. Of the 58 schemes with a control reported as a gap, most of them in digital channels, procurement and people. This is a count of schemes, not a rating of their seriousness.

SECTION 3 · WHERE THE MATERIAL FRAUD EXPOSURE SITS

Open and unresolved fraud schemes

Every scheme with a control reported as a gap or answers to resolve, grouped by area. MK has not yet approved a method for rating fraud risks, so no likelihood, impact or priority is assigned. Each scheme's risk statement is in Appendix B and its finding in Appendix A.

AREA	OPEN	SCHEMES (TIER 1 IN BOLD; ANSWERS TO RESOLVE MARKED)
Third parties and supply chain	12	**A fictitious supplier is created and paid** S01; **Supplier payments are diverted through changed bank details** S02; **A supplier is set up with an account it does not own** S03; **One person can order and approve payment** S04; **Invoices are paid for goods or services not received or not agreed** S05; **An outsourced provider misuses its access** S06; A tender is manipulated or purchases are split S24; Buyers take kickbacks S25; Purchase cards or petty cash are misused S26; Intermediaries pay bribes or inflate fees S27; Variations inflate the agreed value S28; Procurement anomalies are never noticed S51
People, payroll and insider risk	11	**Salaries are redirected through a fake bank change** S07; **Ghost employees are paid** S08; **Leavers stay on the payroll** S09; **A false identity enters at hiring** S10; **A stand-in or deepfake candidate is appointed** S11; The payroll payment file is altered after approval S29; Cash wages are stolen or paid to ghosts S30; Hours and overtime are inflated S31; Expenses and advances are abused S32; Labour brokers invoice for workers who were not there S33; An insider in a high-risk role works unchecked S34
Customers, revenue and products	10	**Refunds are stolen** S12; **Customer details are changed to divert money or goods** S13; **Credit is obtained with fabricated documents** S14; **Claims are fabricated or inflated** S15; Sales are not billed or receipts are diverted S35; Customers pay fraudsters impersonating the organisation S36; Prices are overridden or side deals made S37; Agents report fictitious sales S38; Vouchers and loyalty points are abused S52; Customers are wrongly blocked on a fraud flag S53
Assets, cash and inventory	10	**Cash takings are stolen** S16; **Stock is stolen and hidden in the counts** S17; Portable and fixed assets go missing S39; Data leaves on disposed or reissued devices S40; Assets or scrap are sold off cheaply or without payment S41; Goods are released to an impostor S42; Fuel and fleet are misused S43; Goods go missing in transit S54; High-value materials are stolen by organised groups S55; Losses are never tracked S56
Digital, cyber-enabled and identity fraud	14	**An email account is taken over** S18; **A payment instruction received by email is acted on** S19; **A cloned voice or video instruction is obeyed** S20; **Customer accounts are taken over** S21; **A security compromise is not notified** S22; A help desk reset hands an attacker access S44; Systems that move money are accessed without strong sign-in S45; Personal information is over-exposed or kept too long S46; A SIM swap defeats one-time PIN approvals S47; An AI assistant is manipulated by hidden instructions S48; A compromise is not contained quickly S49; Spoofed email in the organisation's name deceives staff, suppliers or customers S50; The organisation's own information helps attackers S57; The organisation is impersonated to defraud others S58
Ethics, integrity and anti-corruption	1	Donations or sponsorships channel bribes S23

A further 1 scheme has the control that stops it reported in place with a further defence weaker. These are not open schemes; they are in Appendix A and their practices in Appendix C.

WHAT THIS MEANS

58 schemes are open or unresolved across 6 areas, 22 of them in tier 1. The grouping shows where the work sits; it does not rank the schemes, and Section 7 asks management to decide the order.

SECTION 4 · FRAUD SCENARIO PORTFOLIO

How the schemes would work here

Plausible pathways for an organisation with the controls it reported, using the method's own description of each scheme. They are not allegations that any event has occurred.

A fictitious supplier is created and paid

S01 · PROCUREMENT · TIER 1

HOW IT STARTS	An insider or outsider adds a supplier that does not exist and invoices it.
WHY IT MATTERS	Fictitious suppliers enter through onboarding that can be skipped.
WHAT THE ANSWERS SHOW	New supplier process: checks happen only when someone thinks to do them. Behind it, directors identified is partly in place, directors compared with staff is not in place and suppliers re-checked is set out, not yet operating.
WHAT WOULD INTERRUPT IT	Every new supplier goes through a defined process, with set checks and an approval, before it can be paid.
WARNING SIGNS	Fictitious or shell suppliers
LINKS	F01, FR01, C01, C02, C03, C04, C05

Supplier payments are diverted through changed bank details

S02 · PROCUREMENT · TIER 1

HOW IT STARTS	A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed.
WHY IT MATTERS	Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition.
WHAT THE ANSWERS SHOW	Change confirmed with supplier: changes are confirmed, but sometimes using contact details taken from the request itself. Familiar caller still verified: a follow-up call from the 'supplier' is accepted as confirmation.
WHAT WOULD INTERRUPT IT	Every change is confirmed with the supplier using contact details already on file before it takes effect. The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.
WARNING SIGNS	Payment redirection through false bank details or impersonation
LINKS	F02, FR02, C06, C07

A supplier is set up with an account it does not own

S03 · PROCUREMENT · TIER 1

HOW IT STARTS	Payments go to an employee's or fraudster's account from the first invoice.
WHY IT MATTERS	Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe.
WHAT THE ANSWERS SHOW	Bank account verified: accounts are verified through a bank or third-party service for most new suppliers.
WHAT WOULD INTERRUPT IT	Every new supplier's account is verified through a bank or third-party service before the first payment.
WARNING SIGNS	Payment redirection through false bank details or impersonation; Fictitious or shell suppliers
LINKS	F03, FR03, C08

One person can order and approve payment

S04 · PROCUREMENT · TIER 1

HOW IT STARTS	A buyer invents or inflates a purchase and approves its payment.
WHY IT MATTERS	One person who can both order and approve payment can pay a supplier they invented.
WHAT THE ANSWERS SHOW	Orderer is not payment approver: the same person can order and approve payment.
WHAT WOULD INTERRUPT IT	The duties are always separated, or any exception is approved and recorded.
WARNING SIGNS	Kickbacks and bribery; Duplicate or false invoices
LINKS	F04, FR04, C09

Invoices are paid for goods or services not received or not agreed

S05 · PROCUREMENT · TIER 1

HOW IT STARTS	Overbilling, fictitious deliveries or inflated rates are paid.
WHY IT MATTERS	Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.
WHAT THE ANSWERS SHOW	Three-way match: invoices are paid without being checked against what was approved or received. Behind it, approved order before commitment is partly in place, receipt recorded before payment is partly in place and quantities checked is not in place.
WHAT WOULD INTERRUPT IT	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.
WARNING SIGNS	Duplicate or false invoices; Goods or services paid for but not received
LINKS	F05, FR05, C14, C10, C11, C12, C13

An outsourced provider misuses its access

S06 · PROCUREMENT · TIER 1

HOW IT STARTS	A provider that handles money, customers or data has wider access than the service needs.
WHY IT MATTERS	Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought.
WHAT THE ANSWERS SHOW	Provider access limited: access is limited to what the service needs for the main providers.
WHAT WOULD INTERRUPT IT	Every provider's access is limited to what the service needs, logged and reviewed at least once a year.
WARNING SIGNS	Fraud inside outsourced service providers
LINKS	F06, FR06, C15

52 further open schemes are described in Appendices A and B.

SECTION 5 · THE CONTROL ENVIRONMENT MANAGEMENT SHOULD BUILD

Target controls, by programme

One programme for each accountable role. Each control is described in full once, in Appendix C, with the draft method's standard; here it is named with its reference and what it is for.

Finance lead

23 CONTROLS

STOPS

supplier payments are diverted through changed bank details, invoices are paid for goods or services not received or not agreed, credit is obtained with fabricated documents, stock is stolen and hidden in the counts, purchase cards or petty cash are misused, cash wages are stolen or paid to ghosts, expenses and advances are abused and sales are not billed or receipts are diverted and 4 more.

PUT IN PLACE

Change confirmed with supplier (C06, partly in place); Familiar caller still verified (C07, not in place); Three-way match (C14, not in place); Application documents verified (C36, partly in place); Independent blind counts (C45, partly in place); Independent reconciliation (C62, not in place); Two people pay out cash (C69, not in place); Claims approved by a manager (C71, partly in place); Everything supplied is billed (C79, partly in place); Customers warned about payment redirection (C80, partly in place); Paid before collection (C85, partly in place); Senior review of supplier payments (C98, set out, not yet operating); Losses tracked and reported (C103, set out, not yet operating).

STRENGTHEN

10 further defences reported weaker behind a control reported in place or a gap: C35, C37, C38, C39, C40, C41, C44, C46, C47, C48 (Appendix C).

IT lead

10 CONTROLS

STOPS

an email account is taken over, a payment instruction received by email is acted on, customer accounts are taken over, a security compromise is not notified, a help desk reset hands an attacker access, systems that move money are accessed without strong sign-in, a SIM swap defeats one-time PIN approvals and an AI assistant is manipulated by hidden instructions and 2 more.

PUT IN PLACE

Multi-factor on all email (C50, not in place); Email never enough on its own (C51, not in place); Customer logins protected (C55, partly in place); Compromises reported as POPIA requires (C56, partly in place); Help desk resets verified (C88, partly in place); Multi-factor on critical systems (C89, not in place); Approval numbers protected (C91, partly in place); Assistant permissions limited (C92, partly in place); Compromise playbook (C93, not in place); Domain protected against spoofing (C94, partly in place).

HR and payroll lead

18 CONTROLS

STOPS

salaries are redirected through a fake bank change, ghost employees are paid, leavers stay on the payroll, a false identity enters at hiring, a stand-in or deepfake candidate is appointed, the payroll payment file is altered after approval, hours and overtime are inflated and an insider in a high-risk role works unchecked.

PUT IN PLACE

Bank changes confirmed with employee (C16, not in place); Payroll reviewed by another person (C17, partly in place); Leavers removed before next run (C21, partly in place); Identity verified (C22, partly in place); Remote appointee identity confirmed (C24, partly in place); Payment file protected (C68, not in place); Hours approved by supervisor (C70, set out, not yet operating); Block leave required (C76, partly in place).

STRENGTHEN

10 further defences reported weaker behind a control reported in place or a gap: C18, C19, C20, C23, C73, C74, C75, C77, C78, C106 (Appendix C).

Operations lead

12 CONTROLS

STOPS

cash takings are stolen, labour brokers invoice for workers who were not there, portable and fixed assets go missing, data leaves on disposed or reissued devices, goods are released to an impostor, fuel and fleet are misused, goods go missing in transit and high-value materials are stolen by organised groups.

PUT IN PLACE

Daily reconciliation (C43, partly in place); Broker invoices against attendance (C72, not in place); Register verified physically (C83, not in place); Devices wiped before disposal (C84, partly in place); Changed collection instructions verified (C86, partly in place); Fuel matched to distance (C87, not in place); Dispatch matched to orders (C101, not in place); Organised theft assessed (C102, not in place).

STRENGTHEN

4 further defences reported weaker behind a control reported in place or a gap: C11, C12, C13, C49 (Appendix C).

Commercial and customer lead

15 CONTROLS

STOPS	refunds are stolen, customer details are changed to divert money or goods, claims are fabricated or inflated, prices are overridden or side deals made, agents report fictitious sales, vouchers and loyalty points are abused and the organisation's own information helps attackers.
PUT IN PLACE	Refunds approved independently (C25, partly in place); Customer detail changes verified (C33, partly in place); Fraud indicators screened (C42, partly in place); Non-standard prices approved (C81, not in place); Agent sales verified (C82, not in place); Vouchers controlled in the system (C99, set out, not yet operating); Staff guided on what not to share (C104, not in place).
STRENGTHEN	8 further defences reported weaker behind a control reported in place or a gap: C26, C27, C28, C29, C30, C31, C32, C34 (Appendix C).

Procurement lead

17 CONTROLS

STOPS	a fictitious supplier is created and paid, a supplier is set up with an account it does not own, one person can order and approve payment, an outsourced provider misuses its access, a tender is manipulated or purchases are split, intermediaries pay bribes or inflate fees and variations inflate the agreed value.
PUT IN PLACE	New supplier process (C01, partly in place); Bank account verified (C08, partly in place); Orderer is not payment approver (C09, not in place); Provider access limited (C15, partly in place); Evaluation against set criteria (C60, partly in place); Intermediaries vetted (C63, not in place); Variations approved first (C65, not in place).
STRENGTHEN	10 further defences reported weaker behind a control reported in place or a gap: C02, C03, C04, C05, C10, C59, C64, C66, C67, C97 (Appendix C).

Chief financial officer

4 CONTROLS

STOPS	a cloned voice or video instruction is obeyed and the organisation is impersonated to defraud others.
PUT IN PLACE	Verification for calls, voice notes and video (C52, partly in place); Brand impersonation monitored and removed (C105, not in place).
STRENGTHEN	2 further defences reported weaker behind a control reported in place or a gap: C53, C54 (Appendix C).

Legal and compliance lead

3 CONTROLS

STOPS	buyers take kickbacks and personal information is over-exposed or kept too long.
PUT IN PLACE	Annual interest declarations (C61, not in place); Access to personal information limited (C90, partly in place).
STRENGTHEN	1 further defence reported weaker behind a control reported in place or a gap: C57 (Appendix C).

Ethics lead

1 CONTROL

STOPS	donations or sponsorships channel bribes.
PUT IN PLACE	Recipients checked for links (C58, partly in place).

Fraud risk lead

1 CONTROL

STOPS	customers are wrongly blocked on a fraud flag.
PUT IN PLACE	Human review before a customer is blocked (C100, partly in place).

Internal audit

2 CONTROLS

STRENGTHEN	2 further defences reported weaker behind a control reported in place or a gap: C95, C96 (Appendix C).

WHAT THIS MEANS

59 controls are to be put in place and 47 are further defences to strengthen. The method establishes no dependency among these controls. Where the method describes a control only by its in-place answer, Appendix C says so rather than adding detail the method does not contain.

SECTION 6 · WHO MUST OWN THE RESPONSE

Accountability by role

Roles, not individuals: the assessment does not identify people. The method suggests owners in many forms; this report uses one label per function, and Appendix I lists the method's wording behind each. Oversight: The board or its audit committee, from the organisation's own governance answer.

ROLE	CONTROLS	SCHEMES	ACTIONS	ANSWERS TO RESOLVE OR OBTAIN
Finance lead	23	12	24	None
IT lead	10	10	11	None
HR and payroll lead	18	9	19	None
Operations lead	12	10	13	None
Commercial and customer lead	15	7	16	None
Procurement lead	17	9	18	None
Chief financial officer	4	2	5	None
Legal and compliance lead	3	3	4	None
Ethics lead	1	1	2	None
Fraud risk lead	1	1	2	None
Internal audit	2	1	3	None
Chief executive	0	58	9	Names the accountable executives, decides the order of work and reports status to the board or its audit committee.

SECTION 7 · DECISIONS LEADERSHIP MUST MAKE

The decision agenda

A recommended direction follows the method and the answers; the decision remains management's. No deadline is set: "when" states what each decision must come before.

REF	DECISION	WHY	RECOMMENDED DIRECTION	WHEN	IF DELAYED
D01	**Name one accountable executive for each area with open or unresolved schemes: ethics (1), procurement (12), people (11), customers (10), assets (10) and digital channels (14).**	Each scheme needs one person with authority over the process, the system and the people involved.	The method suggests: ethics lead for ethics, procurement lead for procurement, HR and payroll lead for people, commercial and customer lead for customers and operations lead for assets, and the leads named in the register for the rest.	Before design work starts.	Open schemes have no owner and the controls that stop them stay unassigned.
D02	**Decide which open schemes to address first.**	The draft method does not yet rank fraud risks by likelihood or impact, so this report does not rank them. The tier shows how early the method confirms a scheme, not how serious it is.	Resolve conflicting answers and prerequisites first, as the method requires; order the rest using management's own knowledge of volumes, values and exposure.	Before design work starts.	Effort is spread across every scheme at once, or follows the order of this report, which is not a risk ranking.
D03	**Have the board or its audit committee receive the status of the open and unresolved schemes at each of its meetings until each is closed, deferred with a reason or accepted.**	Regular reporting keeps the schemes visible to the people who can remove blockers.	A one-page status per scheme: owner, controls in place, controls outstanding, next step.	From the first meeting after this report.	Progress is not visible until the next assessment.

SECTION 8 · WHAT SHOULD HAPPEN, AND IN WHAT ORDER

The implementation programme

Six phases, ordered by what must be known and decided before controls are built. No dates are set from a scheme's tier or answers; management sets them. Every action is in Appendix E.

#	PHASE	PURPOSE	ACTIONS	INCLUDES
2	**Decide and assign**	Name who is accountable for each area, decide which open schemes to address in this cycle and approve the target designs.	8	Name the executive accountable for ethics, where 1 scheme is open or unresolved. Name the executive accountable for procurement, where 12 schemes are open or unresolved. Name the executive accountable for people, where 11 schemes are open or unresolved. 5 more in Appendix E.
4	**Put the remaining controls in place**	The controls reported as gaps for the schemes management has selected.	59	Put in place: new supplier process (C01). Put in place: change confirmed with supplier (C06). Put in place: familiar caller still verified (C07). 56 more in Appendix E.
5	**Strengthen further defences**	Practices reported weaker behind a control reported in place.	47	Strengthen: directors identified (C02). Strengthen: directors compared with staff (C03). Strengthen: suppliers re-checked (C04). 44 more in Appendix E.
6	**Operate, measure and report**	Run each control through a full cycle, check it against its success measure and report status to the oversight body.	12	Run the 17 controls owned by the procurement lead through a full cycle and check each against its success measure. Run the 23 controls owned by the finance lead through a full cycle and check each against its success measure. Run the 12 controls owned by the operations lead through a full cycle and check each against its success measure. 9 more in Appendix E.

WHAT THIS MEANS

Phases 1 and 2 need no new control: they establish the facts, name owners and choose the order of work. No control in this report relies on another, as far as the method establishes, so phases 3 and 4 can run together. Phase 6 runs each control through a full cycle and reports status to the board or its audit committee.

SECTION 9 · HOW MANAGEMENT WILL KNOW IT IS WORKING

Measures and reporting

Each control has one success measure, in the method's own terms (Appendix F). These are the signals management should expect once a control operates; they are not a claim that they exist today.

INDICATOR	TODAY	EXPECTED
Open schemes with a named owner and a recorded decision	None recorded (58 open)	Every open scheme selected, deferred with a reason or accepted
Controls meeting their success measure for a full cycle	Not measured	Each control put in place (59)
Status reported to the board or its audit committee	Not yet	At each meeting until each scheme is closed, deferred or accepted

Measures by programme

PROGRAMME	MEASURES	EXAMPLE
Finance lead	23	Records for the period show this practice applied to every case in scope: full counts.
IT lead	10	Records for the period show this practice applied to every case in scope: assistant permissions limited.
HR and payroll lead	18	Records for the period show this practice applied to every case in scope: training on joining.
Operations lead	12	Records for the period show this practice applied to every case in scope: quantities checked.
Commercial and customer lead	15	Records for the period show this practice applied to every case in scope: defined onboarding.
Procurement lead	17	Records for the period show this practice applied to every case in scope: contract register.
Chief financial officer	4	Records for the period show this practice applied to every case in scope: brand impersonation monitored and removed.
Legal and compliance lead	3	Records for the period show this practice applied to every case in scope: affected people warned.
Ethics lead	1	Records for the period show this practice applied to every case in scope: recipients checked for links.
Fraud risk lead	1	Records for the period show this practice applied to every case in scope: human review before a customer is blocked.
Internal audit	2	Records for the period show this practice applied to every case in scope: data reviewed for unusual patterns.

CONCLUSION

Fictional Retail Group (mixed controls)'s answers show 48 schemes with the controls that stop them reported in place and 58 with a control reported as a gap. The order of the remaining work is management's decision, because the draft method does not yet rank fraud risks; this report sets out what each scheme needs, who owns it and how management will know it is working.

APPENDIX A

Finding register

Every scheme with a control reported as a gap, answers to resolve, or a further defence weaker. "What the answers show" is self-reported and has not been verified. A scheme with answers to resolve is not treated as covered until they are resolved; a further defence reported weaker does not change the answer given for the control that stops the scheme.

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F01 S01	**A fictitious supplier is created and paid** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	New supplier process: checks happen only when someone thinks to do them. Supporting practices also reported weaker: directors identified (partly in place), directors compared with staff (not in place), suppliers re-checked (set out, not yet operating) and dormant suppliers deactivated (not in place). Answered by the respondent and Procurement.	An insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped.	FR01, C01, C02, C03, C04, C05
F02 S02	**Supplier payments are diverted through changed bank details** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	Change confirmed with supplier: changes are confirmed, but sometimes using contact details taken from the request itself. Familiar caller still verified: a follow-up call from the 'supplier' is accepted as confirmation. Answered by the respondent.	A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition.	FR02, C06, C07
F03 S03	**A supplier is set up with an account it does not own** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	Bank account verified: accounts are verified through a bank or third-party service for most new suppliers. Answered by the respondent.	Payments go to an employee's or fraudster's account from the first invoice. Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe.	FR03, C08
F04 S04	**One person can order and approve payment** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	Orderer is not payment approver: the same person can order and approve payment. Answered by the respondent.	A buyer invents or inflates a purchase and approves its payment. One person who can both order and approve payment can pay a supplier they invented.	FR04, C09

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F05 S05	**Invoices are paid for goods or services not received or not agreed** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	Three-way match: invoices are paid without being checked against what was approved or received. Supporting practices also reported weaker: approved order before commitment (partly in place), receipt recorded before payment (partly in place), quantities checked (not in place) and services confirmed (not in place). Answered by Procurement, Operations and sales and the respondent.	Overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.	FR05, C14, C10, C11, C12, C13
F06 S06	**An outsourced provider misuses its access** Third parties and supply chain · tier 1 CONTROL REPORTED AS A GAP	Provider access limited: access is limited to what the service needs for the main providers. Answered by the respondent.	A provider that handles money, customers or data has wider access than the service needs. Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought.	FR06, C15
F07 S07	**Salaries are redirected through a fake bank change** People, payroll and insider risk · tier 1 CONTROL REPORTED AS A GAP	Bank changes confirmed with employee: bank detail changes are made as requested. Answered by the respondent.	A request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast.	FR07, C16
F08 S08	**Ghost employees are paid** People, payroll and insider risk · tier 1 CONTROL REPORTED AS A GAP	Payroll reviewed by another person: someone else looks at totals, but not the detail. Supporting practices also reported weaker: headcount verification done (not in place), payroll data analysed (set out, not yet operating) and independent review of payroll (partly in place). Answered by the respondent and HR and payroll.	Fictitious or departed people stay on the payroll. A payroll that nobody independent reviews before payment is where ghost employees hide.	FR08, C17, C18, C19, C20
F09 S09	**Leavers stay on the payroll** People, payroll and insider risk · tier 1 CONTROL REPORTED AS A GAP	Leavers removed before next run: removal is checked for some leavers. Answered by the respondent.	A leaver keeps being paid, often to an account someone else controls. Leavers who stay on the payroll are the commonest ghost employees.	FR09, C21
F10 S10	**A false identity enters at hiring** People, payroll and insider risk · tier 1 CONTROL REPORTED AS A GAP	Identity verified: ID documents are checked by eye for some appointments. Supporting practices also reported weaker: qualifications verified (partly in place). Answered by the respondent and HR and payroll.	Someone is employed under a stolen or invented identity or false qualifications. False identities enter at hiring and are hard to remove afterwards.	FR10, C22, C23
F11 S11	**A stand-in or deepfake candidate is appointed** People, payroll and insider risk · tier 1 CONTROL REPORTED AS A GAP	Remote appointee identity confirmed: some appointments include a further check, depending on the manager. Answered by the respondent.	A remote hire is not the person who was interviewed or who does the work. Deepfake and stand-in candidates are now a recorded way into organisations.	FR11, C24

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F12 S12	**Refunds are stolen** Customers, revenue and products · tier 1 CONTROL REPORTED AS A GAP	Refunds approved independently: approval is sought only for large refunds or when staff are unsure. Supporting practices also reported weaker: refunds to the original source (not in place), returns received before credit (not in place), refund patterns reviewed (partly in place), post-period reversals reviewed (partly in place) and claim evidence checked for AI (not in place). Answered by the respondent and Operations and sales.	One person raises and approves refunds or credit notes to themselves or accomplices. Refunds processed and approved by one person are a classic way to steal.	FR12, C25, C26, C27, C28, C29, C30
F13 S13	**Customer details are changed to divert money or goods** Customers, revenue and products · tier 1 CONTROL REPORTED AS A GAP	Customer detail changes verified: most changes are verified with the customer, but sales staff can still make them. Supporting practices also reported weaker: defined onboarding (not in place), business customers verified (partly in place) and shared details flagged (not in place). Answered by Operations and sales and the respondent.	Refund accounts, delivery addresses or contact numbers are changed without the customer. Changed customer details are how refunds and goods are redirected.	FR13, C33, C31, C32, C34
F14 S14	**Credit is obtained with fabricated documents** Customers, revenue and products · tier 1 CONTROL REPORTED AS A GAP	Application documents verified: documents are checked only if something looks wrong. Supporting practices also reported weaker: credit approved independently (partly in place), bureau and fraud database checks (partly in place), early defaults investigated (partly in place), limit and terms changes approved (set out, not yet operating) and payments matched to invoices (not in place) and 1 more. Answered by Finance and the respondent.	Fake payslips and bank statements, now easy to generate, secure credit that is never repaid. Application fraud with fabricated documents drives credit losses.	FR14, C36, C35, C37, C38, C39, C40, C41
F15 S15	**Claims are fabricated or inflated** Customers, revenue and products · tier 1 CONTROL REPORTED AS A GAP	Fraud indicators screened: assessors rely on their own experience, without set indicators. Answered by the respondent.	False warranty, guarantee or insurance claims are paid. Claims fraud is the main fraud risk for organisations that pay claims.	FR15, C42
F16 S16	**Cash takings are stolen** Assets, cash and inventory · tier 1 CONTROL REPORTED AS A GAP	Daily reconciliation: takings are reconciled occasionally, or only when there is a shortage. Answered by the respondent.	Takings are under-recorded or removed before banking. Daily reconciliation of takings is the main control over cash theft.	FR16, C43

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F17 S17	**Stock is stolen and hidden in the counts** Assets, cash and inventory · tier 1 CONTROL REPORTED AS A GAP	Independent blind counts: the stores team counts, and someone else glances at the results. Supporting practices also reported weaker: how stock is recorded (not in place), full counts (partly in place), differences explained before adjusting (not in place), write-offs approved and supervised (not in place) and shrinkage tracked (set out, not yet operating). Answered by Operations and sales, Finance and the respondent.	The people who hold stock also count it. Counts done by the people who hold the stock can hide its theft.	FR17, C45, C49, C44, C46, C47, C48
F18 S18	**An email account is taken over** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Multi-factor on all email: email accounts are protected by passwords only. Answered by the respondent.	A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.	FR18, C50
F19 S19	**A payment instruction received by email is acted on** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Email never enough on its own: payment changes received by email are acted on as received. Answered by the respondent.	Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds.	FR19, C51
F20 S20	**A cloned voice or video instruction is obeyed** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Verification for calls, voice notes and video: some staff check unusual requests, depending on their own judgement. Supporting practices also reported weaker: changes to call-back details verified (partly in place) and executives and their teams prepared (partly in place). Answered by the respondent and Finance.	A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds.	FR20, C52, C54, C53
F21 S21	**Customer accounts are taken over** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Customer logins protected: multi-factor authentication is offered, but customers can opt out. Answered by the respondent.	Stolen passwords or SIM swaps are used to drain customer accounts. Customer accounts without takeover protection are drained with stolen passwords.	FR21, C55
F22 S22	**A security compromise is not notified** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Compromises reported as POPIA requires: a compromise would be handled as it happens, without a set process. Supporting practices also reported weaker: affected people warned (not in place). Answered by IT and information and the respondent.	The Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible.	FR22, C56, C57
F23 S23	**Donations or sponsorships channel bribes** Ethics, integrity and anti-corruption · tier 2 CONTROL REPORTED AS A GAP	Recipients checked for links: reported in place only in some areas, cases or periods. Answered by the respondent.	A payment to a cause linked to a decision-maker buys influence.	FR23, C58

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F24 S24	**A tender is manipulated or purchases are split** Third parties and supply chain · tier 2 CONTROL REPORTED AS A GAP	Evaluation against set criteria: criteria exist, but they are sometimes set or changed after bids arrive. Supporting practices also reported weaker: quote and tender thresholds (not in place). Answered by Procurement and the respondent.	Specifications, evaluation or thresholds are bent towards a chosen supplier.	FR24, C60, C59
F25 S25	**Buyers take kickbacks** Third parties and supply chain · tier 2 CONTROL REPORTED AS A GAP	Annual interest declarations: buying staff do not declare interests. Answered by the respondent.	A long-standing buyer-supplier relationship hides favours.	FR25, C61
F26 S26	**Purchase cards or petty cash are misused** Third parties and supply chain · tier 2 CONTROL REPORTED AS A GAP	Independent reconciliation: reported as not in place. Answered by the respondent.	Personal purchases or split transactions go unreviewed.	FR26, C62
F27 S27	**Intermediaries pay bribes or inflate fees** Third parties and supply chain · tier 2 CONTROL REPORTED AS A GAP	Intermediaries vetted: reported as not in place. Answered by the respondent.	Agents act improperly or bill for work not done.	FR27, C63
F28 S28	**Variations inflate the agreed value** Third parties and supply chain · tier 2 CONTROL REPORTED AS A GAP	Variations approved first: reported as not in place. Supporting practices also reported weaker: written supplier contracts (partly in place), contract register (not in place) and large variations escalated (set out, not yet operating). Answered by Procurement and the respondent.	Extra scope or rates are approved after the work is done.	FR28, C65, C67, C64, C66
F29 S29	**The payroll payment file is altered after approval** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Payment file protected: not in place. Answered by the respondent.	Account numbers or amounts change between approval and the bank.	FR29, C68
F30 S30	**Cash wages are stolen or paid to ghosts** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Two people pay out cash: reported as not in place. Answered by the respondent.	Cash pay-outs are not witnessed or reconciled.	FR30, C69
F31 S31	**Hours and overtime are inflated** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Hours approved by supervisor: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Unworked hours or overtime are approved and paid.	FR31, C70
F32 S32	**Expenses and advances are abused** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Claims approved by a manager: reported in place only in some areas, cases or periods. Answered by the respondent.	False or inflated claims are paid.	FR32, C71
F33 S33	**Labour brokers invoice for workers who were not there** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Broker invoices against attendance: reported as not in place. Answered by the respondent.	Broker or casual worker numbers are inflated.	FR33, C72

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F34 S34	**An insider in a high-risk role works unchecked** People, payroll and insider risk · tier 2 CONTROL REPORTED AS A GAP	Block leave required: most people in sensitive roles take block leave, with someone else doing their work. Supporting practices also reported weaker: high-risk roles identified (partly in place), no conflicting duties when covering (set out, not yet operating), no single point of knowledge (set out, not yet operating), concerns raised fairly (not in place) and support for financial pressure (not in place). Answered by HR and payroll and the respondent.	Someone who never hands over work conceals an ongoing fraud.	FR34, C76, C73, C74, C75, C77, C78
F35 S35	**Sales are not billed or receipts are diverted** Customers, revenue and products · tier 2 CONTROL REPORTED AS A GAP	Everything supplied is billed: billing depends on staff remembering. Answered by the respondent.	Goods or services are provided without an invoice, or payments are taken off the books.	FR35, C79
F36 S36	**Customers pay fraudsters impersonating the organisation** Customers, revenue and products · tier 2 CONTROL REPORTED AS A GAP	Customers warned about payment redirection: the bank account appears on invoices, but there is no warning about changes. Answered by the respondent.	Customers receive fake banking details and pay the wrong account.	FR36, C80
F37 S37	**Prices are overridden or side deals made** Customers, revenue and products · tier 2 CONTROL REPORTED AS A GAP	Non-standard prices approved: reported as not in place. Answered by the respondent.	Discounts or terms favour a customer in return for a kickback.	FR37, C81
F38 S38	**Agents report fictitious sales** Customers, revenue and products · tier 2 CONTROL REPORTED AS A GAP	Agent sales verified: reported as not in place. Answered by the respondent.	Commission is paid on customers who do not exist or soon cancel.	FR38, C82
F39 S39	**Portable and fixed assets go missing** Assets, cash and inventory · tier 2 CONTROL REPORTED AS A GAP	Register verified physically: the register is never checked against the assets. Answered by the respondent.	Laptops, tools or equipment disappear without being noticed.	FR39, C83
F40 S40	**Data leaves on disposed or reissued devices** Assets, cash and inventory · tier 2 CONTROL REPORTED AS A GAP	Devices wiped before disposal: reported in place only in some areas, cases or periods. Answered by the respondent.	Devices are sold, reissued or returned without being wiped.	FR40, C84
F41 S41	**Assets or scrap are sold off cheaply or without payment** Assets, cash and inventory · tier 2 CONTROL REPORTED AS A GAP	Paid before collection: payment is confirmed in the bank for larger sales only. Answered by the respondent.	Disposals favour insiders or goods leave before payment.	FR41, C85
F42 S42	**Goods are released to an impostor** Assets, cash and inventory · tier 2 CONTROL REPORTED AS A GAP	Changed collection instructions verified: reported in place only in some areas, cases or periods. Answered by the respondent.	A changed delivery or collection instruction sends goods to a fraudster.	FR42, C86
F43 S43	**Fuel and fleet are misused** Assets, cash and inventory · tier 2 CONTROL REPORTED AS A GAP	Fuel matched to distance: fuel purchases are not compared with vehicle use. Answered by the respondent.	Fuel cards or vehicles are used privately or fraudulently.	FR43, C87
F44 S44	**A help desk reset hands an attacker access** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Help desk resets verified: most resets need verification through a trusted route, such as the person's manager or a number on file. Answered by the respondent.	An impersonator persuades the help desk to reset a password or authenticator.	FR44, C88

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F45 S45	**Systems that move money are accessed without strong sign-in** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Multi-factor on critical systems: these systems are protected by passwords only. Answered by the respondent.	Remote access, cloud or banking systems rely on passwords alone.	FR45, C89
F46 S46	**Personal information is over-exposed or kept too long** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Access to personal information limited: access is limited for some systems only. Answered by the respondent.	Too many people can reach or export personal information, or records outlive their purpose.	FR46, C90
F47 S47	**A SIM swap defeats one-time PIN approvals** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Approval numbers protected: staff have been told about SIM swaps, but nothing has been changed. Answered by the respondent.	Approvals sent by SMS are intercepted.	FR47, C91
F48 S48	**An AI assistant is manipulated by hidden instructions** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Assistant permissions limited: reported in place only in some areas, cases or periods. Answered by the respondent.	Instructions planted in emails or documents make an assistant leak data or act.	FR48, C92
F49 S49	**A compromise is not contained quickly** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Compromise playbook: there is no plan; each case would be handled from scratch. Answered by the respondent.	Accounts stay compromised while suppliers and customers keep receiving instructions.	FR49, C93
F50 S50	**Spoofed email in the organisation's name deceives staff, suppliers or customers** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Domain protected against spoofing: partly in place. Answered by the respondent.	Emails that appear to come from the organisation's own domain carry false payment instructions.	FR50, C94
F51 S51	**Procurement anomalies are never noticed** Third parties and supply chain · tier 3 CONTROL REPORTED AS A GAP	Senior review of supplier payments: reported as set out or agreed but not yet working in practice. Supporting practices also reported weaker: split orders monitored (set out, not yet operating), data reviewed for unusual patterns (not in place) and independent review of procurement (partly in place). Answered by Procurement, the respondent and Risk and investigations.	Patterns such as splitting or duplicates go unseen.	FR51, C98, C97, C95, C96
F52 S52	**Vouchers and loyalty points are abused** Customers, revenue and products · tier 3 CONTROL REPORTED AS A GAP	Vouchers controlled in the system: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Staff issue or redeem value to themselves or associates.	FR52, C99
F53 S53	**Customers are wrongly blocked on a fraud flag** Customers, revenue and products · tier 3 CONTROL REPORTED AS A GAP	Human review before a customer is blocked: reported in place only in some areas, cases or periods. Answered by the respondent.	An automated flag is treated as proof and a customer is penalised without review.	FR53, C100
F54 S54	**Goods go missing in transit** Assets, cash and inventory · tier 3 CONTROL REPORTED AS A GAP	Dispatch matched to orders: reported as not in place. Answered by the respondent.	Loads are short-delivered or diverted.	FR54, C101
F55 S55	**High-value materials are stolen by organised groups** Assets, cash and inventory · tier 3 CONTROL REPORTED AS A GAP	Organised theft assessed: reported as not in place. Answered by the respondent.	Copper, cable, fuel or similar are stolen with insider help.	FR55, C102
F56 S56	**Losses are never tracked** Assets, cash and inventory · tier 3 CONTROL REPORTED AS A GAP	Losses tracked and reported: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Shrinkage and losses are written off without analysis.	FR56, C103

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F57 S57	**The organisation's own information helps attackers** Digital, cyber-enabled and identity fraud · tier 3 CONTROL REPORTED AS A GAP	Staff guided on what not to share: reported as not in place. Answered by the respondent.	Published staff details and routines make impersonation easier.	FR57, C104
F58 S58	**The organisation is impersonated to defraud others** Digital, cyber-enabled and identity fraud · tier 3 CONTROL REPORTED AS A GAP	Brand impersonation monitored and removed: reported as not in place. Answered by the respondent.	Fake websites, accounts or job adverts in the organisation's name collect money or personal information.	FR58, C105
F59 S59	**Staff do not know or understand what is expected** Ethics, integrity and anti-corruption · tier 3 CONTROL IN PLACE; FURTHER DEFENCES WEAKER	Code accessible to staff: reported in place across everything it should cover. Further defences reported weaker: training on joining (partly in place). Answered by the respondent, HR and payroll and Legal, compliance and ethics.	Expectations are not communicated in a way people understand, and nobody checks.	C106

APPENDIX B

Fraud risk register

One risk for each open or unresolved scheme. No likelihood, impact, priority or monetary value is assigned: MK has not yet approved a method for rating them.

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR01 F01	**An insider or outsider adds a supplier that does not exist and invoices it, because new supplier process is partly in place.** Fictitious suppliers enter through onboarding that can be skipped.	Checks happen only when someone thinks to do them.	C01 New supplier process; C02 Directors identified; C03 Directors compared with staff; C04 Suppliers re-checked; C05 Dormant suppliers deactivated	Procurement lead	Not rated
FR02 F02	**A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed, because change confirmed with supplier is partly in place and familiar caller still verified is not in place.** Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition.	Changes are confirmed, but sometimes using contact details taken from the request itself. A follow-up call from the 'supplier' is accepted as confirmation.	C06 Change confirmed with supplier; C07 Familiar caller still verified	Finance lead	Not rated
FR03 F03	**Payments go to an employee's or fraudster's account from the first invoice, because bank account verified is partly in place.** Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe.	Accounts are verified through a bank or third-party service for most new suppliers.	C08 Bank account verified	Procurement lead	Not rated
FR04 F04	**A buyer invents or inflates a purchase and approves its payment, because orderer is not payment approver is not in place.** One person who can both order and approve payment can pay a supplier they invented.	The same person can order and approve payment.	C09 Orderer is not payment approver	Procurement lead	Not rated
FR05 F05	**Overbilling, fictitious deliveries or inflated rates are paid, because three-way match is not in place.** Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.	Invoices are paid without being checked against what was approved or received.	C14 Three-way match; C10 Approved order before commitment; C11 Receipt recorded before payment; C12 Quantities checked; C13 Services confirmed	Finance lead	Not rated
FR06 F06	**A provider that handles money, customers or data has wider access than the service needs, because provider access limited is partly in place.** Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought.	Access is limited to what the service needs for the main providers.	C15 Provider access limited	Procurement lead	Not rated
FR07 F07	**A request that appears to come from an employee changes where their salary is paid, because bank changes confirmed with employee is not in place.** Salary redirection through fake bank change requests is common and fast.	Bank detail changes are made as requested.	C16 Bank changes confirmed with employee	HR and payroll lead	Not rated
FR08 F08	**Fictitious or departed people stay on the payroll, because payroll reviewed by another person is partly in place.** A payroll that nobody independent reviews before payment is where ghost employees hide.	Someone else looks at totals, but not the detail.	C17 Payroll reviewed by another person; C18 Headcount verification done; C19 Payroll data analysed; C20 Independent review of payroll	HR and payroll lead	Not rated
FR09 F09	**A leaver keeps being paid, often to an account someone else controls, because leavers removed before next run is partly in place.** Leavers who stay on the payroll are the commonest ghost employees.	Removal is checked for some leavers.	C21 Leavers removed before next run	HR and payroll lead	Not rated

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR10 F10	**Someone is employed under a stolen or invented identity or false qualifications, because identity verified is partly in place.** False identities enter at hiring and are hard to remove afterwards.	ID documents are checked by eye for some appointments.	C22 Identity verified; C23 Qualifications verified	HR and payroll lead	Not rated
FR11 F11	**A remote hire is not the person who was interviewed or who does the work, because remote appointee identity confirmed is partly in place.** Deepfake and stand-in candidates are now a recorded way into organisations.	Some appointments include a further check, depending on the manager.	C24 Remote appointee identity confirmed	HR and payroll lead	Not rated
FR12 F12	**One person raises and approves refunds or credit notes to themselves or accomplices, because refunds approved independently is partly in place.** Refunds processed and approved by one person are a classic way to steal.	Approval is sought only for large refunds or when staff are unsure.	C25 Refunds approved independently; C26 Refunds to the original source; C27 Returns received before credit; C28 Refund patterns reviewed; C29 Post-period reversals reviewed; C30 Claim evidence checked for AI	Commercial and customer lead	Not rated
FR13 F13	**Refund accounts, delivery addresses or contact numbers are changed without the customer, because customer detail changes verified is partly in place.** Changed customer details are how refunds and goods are redirected.	Most changes are verified with the customer, but sales staff can still make them.	C33 Customer detail changes verified; C31 Defined onboarding; C32 Business customers verified; C34 Shared details flagged	Commercial and customer lead	Not rated
FR14 F14	**Fake payslips and bank statements, now easy to generate, secure credit that is never repaid, because application documents verified is partly in place.** Application fraud with fabricated documents drives credit losses.	Documents are checked only if something looks wrong.	C36 Application documents verified; C35 Credit approved independently; C37 Bureau and fraud database checks; C38 Early defaults investigated; C39 Limit and terms changes approved; C40 Payments matched to invoices; C41 Statements sent from the system	Finance lead	Not rated
FR15 F15	**False warranty, guarantee or insurance claims are paid, because fraud indicators screened is partly in place.** Claims fraud is the main fraud risk for organisations that pay claims.	Assessors rely on their own experience, without set indicators.	C42 Fraud indicators screened	Commercial and customer lead	Not rated
FR16 F16	**Takings are under-recorded or removed before banking, because daily reconciliation is partly in place.** Daily reconciliation of takings is the main control over cash theft.	Takings are reconciled occasionally, or only when there is a shortage.	C43 Daily reconciliation	Operations lead	Not rated
FR17 F17	**The people who hold stock also count it, because independent blind counts is partly in place.** Counts done by the people who hold the stock can hide its theft.	The stores team counts, and someone else glances at the results.	C45 Independent blind counts; C49 How stock is recorded; C44 Full counts; C46 Differences explained before adjusting; C47 Write-offs approved and supervised; C48 Shrinkage tracked	Finance lead	Not rated
FR18 F18	**A mailbox without strong sign-in is used to send or intercept payment instructions, because multi-factor on all email is not in place.** Most business email compromise starts with an account that has no multi-factor authentication.	Email accounts are protected by passwords only.	C50 Multi-factor on all email	IT lead	Not rated
FR19 F19	**Changed details or urgent payments are processed on the strength of an email, because email never enough on its own is not in place.** Acting on payment instructions received by email is how business email compromise succeeds.	Payment changes received by email are acted on as received.	C51 Email never enough on its own	IT lead	Not rated

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR20 F20	**A caller who sounds or looks like a known person is believed, because verification for calls, voice notes and video is partly in place.** Voices and faces can be cloned, so only an agreed verification method holds.	Some staff check unusual requests, depending on their own judgement.	C52 Verification for calls, voice notes and video; C54 Changes to call-back details verified; C53 Executives and their teams prepared	Chief financial officer	Not rated
FR21 F21	**Stolen passwords or SIM swaps are used to drain customer accounts, because customer logins protected is partly in place.** Customer accounts without takeover protection are drained with stolen passwords.	Multi-factor authentication is offered, but customers can opt out.	C55 Customer logins protected	IT lead	Not rated
FR22 F22	**The Regulator and affected people are not told, so they cannot protect themselves, because compromises reported as POPIA requires is partly in place.** POPIA section 22 requires notification as soon as reasonably possible.	A compromise would be handled as it happens, without a set process.	C56 Compromises reported as POPIA requires; C57 Affected people warned	IT lead	Not rated
FR23 F23	**A payment to a cause linked to a decision-maker buys influence, because recipients checked for links is partly in place.**	Recipients checked for links: reported in place only in some areas, cases or periods.	C58 Recipients checked for links	Ethics lead	Not rated
FR24 F24	**Specifications, evaluation or thresholds are bent towards a chosen supplier, because evaluation against set criteria is partly in place.**	Criteria exist, but they are sometimes set or changed after bids arrive.	C60 Evaluation against set criteria; C59 Quote and tender thresholds	Procurement lead	Not rated
FR25 F25	**A long-standing buyer-supplier relationship hides favours, because annual interest declarations is not in place.**	Buying staff do not declare interests.	C61 Annual interest declarations	Legal and compliance lead	Not rated
FR26 F26	**Personal purchases or split transactions go unreviewed, because independent reconciliation is not in place.**	Independent reconciliation: reported as not in place.	C62 Independent reconciliation	Finance lead	Not rated
FR27 F27	**Agents act improperly or bill for work not done, because intermediaries vetted is not in place.**	Intermediaries vetted: reported as not in place.	C63 Intermediaries vetted	Procurement lead	Not rated
FR28 F28	**Extra scope or rates are approved after the work is done, because variations approved first is not in place.**	Variations approved first: reported as not in place.	C65 Variations approved first; C67 Written supplier contracts; C64 Contract register; C66 Large variations escalated	Procurement lead	Not rated
FR29 F29	**Account numbers or amounts change between approval and the bank, because payment file protected is not in place.**	Payment file protected: not in place.	C68 Payment file protected	HR and payroll lead	Not rated
FR30 F30	**Cash pay-outs are not witnessed or reconciled, because two people pay out cash is not in place.**	Two people pay out cash: reported as not in place.	C69 Two people pay out cash	Finance lead	Not rated
FR31 F31	**Unworked hours or overtime are approved and paid, because hours approved by supervisor is set out, not yet operating.**	Hours approved by supervisor: reported as set out or agreed but not yet working in practice.	C70 Hours approved by supervisor	HR and payroll lead	Not rated
FR32 F32	**False or inflated claims are paid, because claims approved by a manager is partly in place.**	Claims approved by a manager: reported in place only in some areas, cases or periods.	C71 Claims approved by a manager	Finance lead	Not rated
FR33 F33	**Broker or casual worker numbers are inflated, because broker invoices against attendance is not in place.**	Broker invoices against attendance: reported as not in place.	C72 Broker invoices against attendance	Operations lead	Not rated
FR34 F34	**Someone who never hands over work conceals an ongoing fraud, because block leave required is partly in place.**	Most people in sensitive roles take block leave, with someone else doing their work.	C76 Block leave required; C73 High-risk roles identified; C74 No conflicting duties when covering; C75 No single point of knowledge; C77 Concerns raised fairly; C78 Support for financial pressure	HR and payroll lead	Not rated
FR35 F35	**Goods or services are provided without an invoice, or payments are taken off the books, because everything supplied is billed is partly in place.**	Billing depends on staff remembering.	C79 Everything supplied is billed	Finance lead	Not rated

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR36 F36	**Customers receive fake banking details and pay the wrong account, because customers warned about payment redirection is partly in place.**	The bank account appears on invoices, but there is no warning about changes.	C80 Customers warned about payment redirection	Finance lead	Not rated
FR37 F37	**Discounts or terms favour a customer in return for a kickback, because non-standard prices approved is not in place.**	Non-standard prices approved: reported as not in place.	C81 Non-standard prices approved	Commercial and customer lead	Not rated
FR38 F38	**Commission is paid on customers who do not exist or soon cancel, because agent sales verified is not in place.**	Agent sales verified: reported as not in place.	C82 Agent sales verified	Commercial and customer lead	Not rated
FR39 F39	**Laptops, tools or equipment disappear without being noticed, because register verified physically is not in place.**	The register is never checked against the assets.	C83 Register verified physically	Operations lead	Not rated
FR40 F40	**Devices are sold, reissued or returned without being wiped, because devices wiped before disposal is partly in place.**	Devices wiped before disposal: reported in place only in some areas, cases or periods.	C84 Devices wiped before disposal	Operations lead	Not rated
FR41 F41	**Disposals favour insiders or goods leave before payment, because paid before collection is partly in place.**	Payment is confirmed in the bank for larger sales only.	C85 Paid before collection	Finance lead	Not rated
FR42 F42	**A changed delivery or collection instruction sends goods to a fraudster, because changed collection instructions verified is partly in place.**	Changed collection instructions verified: reported in place only in some areas, cases or periods.	C86 Changed collection instructions verified	Operations lead	Not rated
FR43 F43	**Fuel cards or vehicles are used privately or fraudulently, because fuel matched to distance is not in place.**	Fuel purchases are not compared with vehicle use.	C87 Fuel matched to distance	Operations lead	Not rated
FR44 F44	**An impersonator persuades the help desk to reset a password or authenticator, because help desk resets verified is partly in place.**	Most resets need verification through a trusted route, such as the person's manager or a number on file.	C88 Help desk resets verified	IT lead	Not rated
FR45 F45	**Remote access, cloud or banking systems rely on passwords alone, because multi-factor on critical systems is not in place.**	These systems are protected by passwords only.	C89 Multi-factor on critical systems	IT lead	Not rated
FR46 F46	**Too many people can reach or export personal information, or records outlive their purpose, because access to personal information limited is partly in place.**	Access is limited for some systems only.	C90 Access to personal information limited	Legal and compliance lead	Not rated
FR47 F47	**Approvals sent by SMS are intercepted, because approval numbers protected is partly in place.**	Staff have been told about SIM swaps, but nothing has been changed.	C91 Approval numbers protected	IT lead	Not rated
FR48 F48	**Instructions planted in emails or documents make an assistant leak data or act, because assistant permissions limited is partly in place.**	Assistant permissions limited: reported in place only in some areas, cases or periods.	C92 Assistant permissions limited	IT lead	Not rated
FR49 F49	**Accounts stay compromised while suppliers and customers keep receiving instructions, because compromise playbook is not in place.**	There is no plan; each case would be handled from scratch.	C93 Compromise playbook	IT lead	Not rated
FR50 F50	**Emails that appear to come from the organisation's own domain carry false payment instructions, because domain protected against spoofing is partly in place.**	Domain protected against spoofing: partly in place.	C94 Domain protected against spoofing	IT lead	Not rated
FR51 F51	**Patterns such as splitting or duplicates go unseen, because senior review of supplier payments is set out, not yet operating.**	Senior review of supplier payments: reported as set out or agreed but not yet working in practice.	C98 Senior review of supplier payments; C97 Split orders monitored; C95 Data reviewed for unusual patterns; C96 Independent review of procurement	Finance lead	Not rated
FR52 F52	**Staff issue or redeem value to themselves or associates, because vouchers controlled in the system is set out, not yet operating.**	Vouchers controlled in the system: reported as set out or agreed but not yet working in practice.	C99 Vouchers controlled in the system	Commercial and customer lead	Not rated
FR53 F53	**An automated flag is treated as proof and a customer is penalised without review, because human review before a customer is blocked is partly in place.**	Human review before a customer is blocked: reported in place only in some areas, cases or periods.	C100 Human review before a customer is blocked	Fraud risk lead	Not rated

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR54 F54	**Loads are short-delivered or diverted, because dispatch matched to orders is not in place.**	Dispatch matched to orders: reported as not in place.	C101 Dispatch matched to orders	Operations lead	Not rated
FR55 F55	**Copper, cable, fuel or similar are stolen with insider help, because organised theft assessed is not in place.**	Organised theft assessed: reported as not in place.	C102 Organised theft assessed	Operations lead	Not rated
FR56 F56	**Shrinkage and losses are written off without analysis, because losses tracked and reported is set out, not yet operating.**	Losses tracked and reported: reported as set out or agreed but not yet working in practice.	C103 Losses tracked and reported	Finance lead	Not rated
FR57 F57	**Published staff details and routines make impersonation easier, because staff guided on what not to share is not in place.**	Staff guided on what not to share: reported as not in place.	C104 Staff guided on what not to share	Commercial and customer lead	Not rated
FR58 F58	**Fake websites, accounts or job adverts in the organisation's name collect money or personal information, because brand impersonation monitored and removed is not in place.**	Brand impersonation monitored and removed: reported as not in place.	C105 Brand impersonation monitored and removed	Chief financial officer	Not rated

APPENDIX C

Control blueprint register

Each control once, with every scheme it serves. The target standard and improving level are the draft method's own wording; "Reported today" is what the organisation answered. Where the method is not specific enough to say more, the row says so with the codes below rather than adding detail the method does not contain.

METHOD DETAIL CODES

- L The method describes this control only by its in-place answer; it has no level descriptions of what partial or full operation looks like.
- R The method names no records management should keep for this control.
- C The method does not say when or how often this control operates.
- I The method describes no level beyond in place for this control.

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C01 Put in place S01	**New supplier process** Checks happen only when someone thinks to do them. Answered by the respondent.	Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Improving level: Compliance with the process is monitored, exceptions are reported and the checks are updated as risks change.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E01. • Review the first full cycle against M01.	Procurement lead E01, M01 Cycle: As the standard and question state
C02 Strengthen S01	**Directors identified** Owners are identified only when something raises a concern. Answered by Procurement.	Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source. Improving level: Ownership is refreshed periodically and when warning signs appear, and changes are reviewed.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E02. • Review the first full cycle against M02.	Procurement lead E02, M02 Cycle: As the standard and question state
C03 Strengthen S01	**Directors compared with staff** Directors compared with staff: reported as not in place. Answered by Procurement.	Directors compared with staff: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M03.	Procurement lead M03 Cycle: Not stated by the method
C04 Strengthen S01	**Suppliers re-checked** Suppliers re-checked: reported as set out or agreed but not yet working in practice. Answered by Procurement.	Suppliers re-checked: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M04.	Procurement lead M04 Cycle: Not stated by the method
C05 Strengthen S01	**Dormant suppliers deactivated** Dormant suppliers deactivated: reported as not in place. Answered by Procurement.	Dormant suppliers deactivated: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M05.	Procurement lead M05 Cycle: Not stated by the method
C06 Put in place S02	**Change confirmed with supplier** Changes are confirmed, but sometimes using contact details taken from the request itself. Answered by the respondent.	Every change is confirmed with the supplier using contact details already on file before it takes effect. Improving level: Confirmations are checked independently, and attempted fraudulent changes are tracked and shared with staff.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E03. • Review the first full cycle against M06.	Finance lead E03, M06 Cycle: As the standard and question state
C07 Put in place S02	**Familiar caller still verified** A follow-up call from the 'supplier' is accepted as confirmation. Answered by the respondent.	The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. Improving level: The rule is tested, for example with simulated calls, and staff report approaches of this kind. Method detail: C	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E04. • Review the first full cycle against M07.	Finance lead E04, M07 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C08 Put in place S03	**Bank account verified** Accounts are verified through a bank or third-party service for most new suppliers. Answered by the respondent.	Every new supplier's account is verified through a bank or third-party service before the first payment. Improving level: Verification is built into the system, so an unverified account cannot be paid, and failures are reported.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E05. • Review the first full cycle against M08.	Procurement lead E05, M08 Cycle: As the standard and question state
C09 Put in place S04	**Orderer is not payment approver** The same person can order and approve payment. Answered by the respondent.	The duties are always separated, or any exception is approved and recorded. Improving level: System access enforces the separation, and conflicts are reported and reviewed. Method detail: C	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E06. • Review the first full cycle against M09.	Procurement lead E06, M09 Cycle: Not stated by the method
C10 Strengthen S05	**Approved order before commitment** Most purchases are approved before commitment, through a purchase order or another record. Answered by Procurement.	Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. Improving level: The system prevents commitment without approval, and purchases made without one are reported and followed up.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E07. • Review the first full cycle against M10.	Procurement lead E07, M10 Cycle: As the standard and question state
C11 Strengthen S05	**Receipt recorded before payment** Receipt is recorded for most deliveries, but not always before payment. Answered by Operations and sales.	Receipt is always recorded before the related invoice is paid. Improving level: The system will not pay without a receipt record, and gaps are reported.	• Agree the design with the operations lead, so that it meets the target standard at level 4. • Keep the records in E08. • Review the first full cycle against M11.	Operations lead E08, M11 Cycle: As the standard and question state
C12 Strengthen S05	**Quantities checked** Quantities checked: reported as not in place. Answered by Operations and sales.	Quantities checked: in place across everything it should cover. Method detail: L R C	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M12.	Operations lead M12 Cycle: Not stated by the method
C13 Strengthen S05	**Services confirmed** Services confirmed: reported as not in place. Answered by Operations and sales.	Services confirmed: in place across everything it should cover. Method detail: L R	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M13.	Operations lead M13 Cycle: As the standard and question state
C14 Put in place S05	**Three-way match** Invoices are paid without being checked against what was approved or received. Answered by the respondent.	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. Improving level: Checks are recorded, exceptions are reported and patterns in differences are reviewed.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E09. • Review the first full cycle against M14.	Finance lead E09, M14 Cycle: As the standard and question state
C15 Put in place S06	**Provider access limited** Access is limited to what the service needs for the main providers. Answered by the respondent.	Every provider's access is limited to what the service needs, logged and reviewed at least once a year. Improving level: Provider access is monitored, unusual activity is alerted and access ends automatically when a contract ends.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E10. • Review the first full cycle against M15.	Procurement lead E10, M15 Cycle: As the standard and question state
C16 Put in place S07	**Bank changes confirmed with employee** Bank detail changes are made as requested. Answered by the respondent.	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. Improving level: Confirmations are reviewed before each pay run, and attempted fraudulent changes are tracked and shared with staff.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E11. • Review the first full cycle against M16.	HR and payroll lead E11, M16 Cycle: As the standard and question state

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C17 Put in place S08	**Payroll reviewed by another person** Someone else looks at totals, but not the detail. Answered by the respondent.	Every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded. Improving level: The review follows a standard checklist, exceptions are followed up and findings are tracked over time.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E12. • Review the first full cycle against M17.	HR and payroll lead E12, M17 Cycle: As the standard and question state
C18 Strengthen S08	**Headcount verification done** Headcount verification done: not in place. Answered by HR and payroll.	Headcount verification done: in place. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M18.	HR and payroll lead M18 Cycle: Not stated by the method
C19 Strengthen S08	**Payroll data analysed** Payroll data analysed: reported as set out or agreed but not yet working in practice. Answered by HR and payroll.	Payroll data analysed: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M19.	HR and payroll lead M19 Cycle: Not stated by the method
C20 Strengthen S08	**Independent review of payroll** Independent review of payroll: partly in place. Answered by HR and payroll.	Independent review of payroll: in place. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M20.	HR and payroll lead M20 Cycle: Not stated by the method
C21 Put in place S09	**Leavers removed before next run** Removal is checked for some leavers. Answered by the respondent.	Every leaver is confirmed as removed before the next pay run, using the HR leaver list. Improving level: Leaver lists and payroll are reconciled each month, and any late removal is reviewed.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E13. • Review the first full cycle against M21.	HR and payroll lead E13, M21 Cycle: As the standard and question state
C22 Put in place S10	**Identity verified** ID documents are checked by eye for some appointments. Answered by the respondent.	Every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start. Improving level: Verification results are checked before payroll is activated, and failures are reviewed and reported.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E14. • Review the first full cycle against M22.	HR and payroll lead E14, M22 Cycle: As the standard and question state
C23 Strengthen S10	**Qualifications verified** Certificates are accepted as presented. Answered by HR and payroll.	Every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final. Improving level: Verification is repeated when people are promoted on the strength of new qualifications, and false claims are dealt with consistently.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E15. • Review the first full cycle against M23.	HR and payroll lead E15, M23 Cycle: As the standard and question state
C24 Put in place S11	**Remote appointee identity confirmed** Some appointments include a further check, depending on the manager. Answered by the respondent.	Every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person. Improving level: The check is repeated after appointment, and failed or suspicious checks are reported and reviewed.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E16. • Review the first full cycle against M24.	HR and payroll lead E16, M24 Cycle: As the standard and question state
C25 Put in place S12	**Refunds approved independently** Approval is sought only for large refunds or when staff are unsure. Answered by the respondent.	Every refund and credit note is approved by someone other than the person who processes it. Improving level: The system enforces the approval, and approvals are reviewed for patterns.	• Agree the design with the commercial and customer lead, so that it meets the target standard at level 4. • Keep the records in E17. • Review the first full cycle against M25.	Commercial and customer lead E17, M25 Cycle: As the standard and question state

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C26 Strengthen S12	**Refunds to the original source** Refunds are paid wherever the customer asks. Answered by Operations and sales.	Every refund goes to the original payment method or to a customer account verified before payment. Improving level: Exceptions are approved and reviewed, and refunds to changed accounts are monitored.	• Agree the design with the commercial and customer lead, so that it meets the target standard at level 4. • Keep the records in E18. • Review the first full cycle against M26.	Commercial and customer lead E18, M26 Cycle: As the standard and question state
C27 Strengthen S12	**Returns received before credit** Returns received before credit: reported as not in place. Answered by Operations and sales.	Returns received before credit: in place across everything it should cover. Method detail: L R	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M27.	Commercial and customer lead M27 Cycle: As the standard and question state
C28 Strengthen S12	**Refund patterns reviewed** Refund patterns reviewed: reported in place only in some areas, cases or periods. Answered by Operations and sales.	Refund patterns reviewed: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M28.	Commercial and customer lead M28 Cycle: Not stated by the method
C29 Strengthen S12	**Post-period reversals reviewed** Post-period reversals reviewed: reported in place only in some areas, cases or periods. Answered by Operations and sales.	Post-period reversals reviewed: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M29.	Commercial and customer lead M29 Cycle: Not stated by the method
C30 Strengthen S12	**Claim evidence checked for AI** Claim evidence checked for AI: reported as not in place. Answered by Operations and sales.	Claim evidence checked for AI: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M30.	Commercial and customer lead M30 Cycle: Not stated by the method
C31 Strengthen S13	**Defined onboarding** Defined onboarding: reported as not in place. Answered by Operations and sales.	Defined onboarding: in place across everything it should cover. Method detail: L R	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M31.	Commercial and customer lead M31 Cycle: As the standard and question state
C32 Strengthen S13	**Business customers verified** Business customers verified: reported in place only in some areas, cases or periods. Answered by Operations and sales.	Business customers verified: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M32.	Commercial and customer lead M32 Cycle: Not stated by the method
C33 Put in place S13	**Customer detail changes verified** Most changes are verified with the customer, but sales staff can still make them. Answered by the respondent.	Every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales. Improving level: Change reports are reviewed independently, and customers are told of every change through their previous contact details.	• Agree the design with the commercial and customer lead, so that it meets the target standard at level 4. • Keep the records in E19. • Review the first full cycle against M33.	Commercial and customer lead E19, M33 Cycle: As the standard and question state
C34 Strengthen S13	**Shared details flagged** Shared details flagged: reported as not in place. Answered by Operations and sales.	Shared details flagged: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M34.	Commercial and customer lead M34 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C35 Strengthen S14	**Credit approved independently** Most credit limits are approved by someone outside sales. Answered by Finance.	Every credit limit is approved by someone other than the salesperson, within set authority levels. Improving level: Limit approvals are reviewed for patterns, and the system prevents sales staff from changing limits.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E20. • Review the first full cycle against M35.	Finance lead E20, M35 Cycle: As the standard and question state
C36 Put in place S14	**Application documents verified** Documents are checked only if something looks wrong. Answered by the respondent.	The key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved. Improving level: Verification results are tracked, and the checks are updated as forged and AI-generated documents change.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E21. • Review the first full cycle against M36.	Finance lead E21, M36 Cycle: As the standard and question state
C37 Strengthen S14	**Bureau and fraud database checks** Bureau and fraud database checks: reported in place only in some areas, cases or periods. Answered by Finance.	Bureau and fraud database checks: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M37.	Finance lead M37 Cycle: As the standard and question state
C38 Strengthen S14	**Early defaults investigated** Early defaults investigated: reported in place only in some areas, cases or periods. Answered by Finance.	Early defaults investigated: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M38.	Finance lead M38 Cycle: Not stated by the method
C39 Strengthen S14	**Limit and terms changes approved** Limit and terms changes approved: reported as set out or agreed but not yet working in practice. Answered by Finance.	Limit and terms changes approved: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M39.	Finance lead M39 Cycle: Not stated by the method
C40 Strengthen S14	**Payments matched to invoices** Customer payments are not matched to invoices. Answered by Finance.	Every payment is matched to the right invoice, and unallocated receipts and misallocations are investigated and cleared promptly. Improving level: Allocation is reviewed independently, and repeated misallocations on the same accounts are investigated for teeming and lading.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E22. • Review the first full cycle against M40.	Finance lead E22, M40 Cycle: As the standard and question state
C41 Strengthen S14	**Statements sent from the system** Statements sent from the system: reported as not in place. Answered by Finance.	Statements sent from the system: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M41.	Finance lead M41 Cycle: Not stated by the method
C42 Put in place S15	**Fraud indicators screened** Assessors rely on their own experience, without set indicators. Answered by the respondent.	Every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred. Improving level: Indicators are refined from confirmed cases, and screening results are monitored.	• Agree the design with the commercial and customer lead, so that it meets the target standard at level 4. • Keep the records in E23. • Review the first full cycle against M42.	Commercial and customer lead E23, M42 Cycle: As the standard and question state
C43 Put in place S16	**Daily reconciliation** Takings are reconciled occasionally, or only when there is a shortage. Answered by the respondent.	Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. Improving level: Shortages and surpluses are tracked by person and cash point, and patterns are investigated.	• Agree the design with the operations lead, so that it meets the target standard at level 4. • Keep the records in E24. • Review the first full cycle against M43.	Operations lead E24, M43 Cycle: As the standard and question state
C44 Strengthen S17	**Full counts** Full counts: reported in place only in some areas, cases or periods. Answered by Finance.	Full counts: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M44.	Finance lead M44 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C45 Put in place S17	**Independent blind counts** The stores team counts, and someone else glances at the results. Answered by the respondent.	Every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. Improving level: Count teams are rotated, recounts are done independently and count accuracy is tracked.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E25. • Review the first full cycle against M45.	Finance lead E25, M45 Cycle: As the standard and question state
C46 Strengthen S17	**Differences explained before adjusting** Differences explained before adjusting: reported as not in place. Answered by Finance.	Differences explained before adjusting: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M46.	Finance lead M46 Cycle: As the standard and question state
C47 Strengthen S17	**Write-offs approved and supervised** Stock is written off by the stores team without approval. Answered by Finance.	Every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record. Improving level: Write-off trends are analysed by product and site, and disposals are spot-checked.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E26. • Review the first full cycle against M47.	Finance lead E26, M47 Cycle: As the standard and question state
C48 Strengthen S17	**Shrinkage tracked** Shrinkage tracked: reported as set out or agreed but not yet working in practice. Answered by Finance.	Shrinkage tracked: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M48.	Finance lead M48 Cycle: Not stated by the method
C49 Strengthen S17	**How stock is recorded** How stock is recorded: it is not formally recorded. Answered by Operations and sales.	How stock is recorded: in an inventory or ERP system or in spreadsheets or manual records. Method detail: L R C	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M49.	Operations lead M49 Cycle: Not stated by the method
C50 Put in place S18	**Multi-factor on all email** Email accounts are protected by passwords only. Answered by the respondent.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. Improving level: Phishing-resistant methods are used for high-risk accounts, and any account without multi-factor authentication is detected and fixed.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E27. • Review the first full cycle against M50.	IT lead E27, M50 Cycle: As the standard and question state
C51 Put in place S19	**Email never enough on its own** Payment changes received by email are acted on as received. Answered by the respondent.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. Improving level: Compliance is checked, and the rule is tested through simulated requests.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E28. • Review the first full cycle against M51.	IT lead E28, M51 Cycle: As the standard and question state
C52 Put in place S20	**Verification for calls, voice notes and video** Some staff check unusual requests, depending on their own judgement. Answered by the respondent.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Improving level: The method is tested, including with simulated deepfake calls, and staff are backed when they delay a senior request to verify it. Method detail: C	• Agree the design with the chief financial officer, so that it meets the target standard at level 4. • Keep the records in E29. • Review the first full cycle against M52.	Chief financial officer E29, M52 Cycle: Not stated by the method
C53 Strengthen S20	**Executives and their teams prepared** Most executives with a public profile have agreed a verification method with their assistants and finance teams. Answered by Finance.	Every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use. Improving level: The methods are tested and refreshed, and attempted impersonations are reported and shared.	• Agree the design with the chief financial officer, so that it meets the target standard at level 4. • Keep the records in E30. • Review the first full cycle against M53.	Chief financial officer E30, M53 Cycle: As the standard and question state

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C54 Strengthen S20	**Changes to call-back details verified** Most changes are verified through the old details or another trusted route. Answered by Finance.	Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Improving level: Changes are logged and reviewed independently, and the holder of the old details is notified.	• Agree the design with the chief financial officer, so that it meets the target standard at level 4. • Keep the records in E31. • Review the first full cycle against M54.	Chief financial officer E31, M54 Cycle: As the standard and question state
C55 Put in place S21	**Customer logins protected** Multi-factor authentication is offered, but customers can opt out. Answered by the respondent.	Customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts. Improving level: Login risk is scored in real time, and protection is adjusted as attack methods change. Method detail: C	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E32. • Review the first full cycle against M55.	IT lead E32, M55 Cycle: Not stated by the method
C56 Put in place S22	**Compromises reported as POPIA requires** A compromise would be handled as it happens, without a set process. Answered by the respondent.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. Improving level: The procedure is tested, used after incidents and reviewed, and notification decisions are recorded. Method detail: C	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E33. • Review the first full cycle against M56.	IT lead E33, M56 Cycle: Not stated by the method
C57 Strengthen S22	**Affected people warned** Affected people warned: reported as not in place. Answered by IT and information.	Affected people warned: in place across everything it should cover. Method detail: L R C	• Agree the design with the legal and compliance lead, so that it meets the target standard. • Review the first full cycle against M57.	Legal and compliance lead M57 Cycle: Not stated by the method
C58 Put in place S23	**Recipients checked for links** Recipients checked for links: reported in place only in some areas, cases or periods. Answered by the respondent.	Recipients checked for links: in place across everything it should cover. Method detail: L R	• Agree the design with the ethics lead, so that it meets the target standard. • Review the first full cycle against M58.	Ethics lead M58 Cycle: As the standard and question state
C59 Strengthen S24	**Quote and tender thresholds** Quote and tender thresholds: reported as not in place. Answered by Procurement.	Quote and tender thresholds: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M59.	Procurement lead M59 Cycle: Not stated by the method
C60 Put in place S24	**Evaluation against set criteria** Criteria exist, but they are sometimes set or changed after bids arrive. Answered by the respondent.	Every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded. Improving level: Evaluations are reviewed for consistency and bias, and the criteria are improved over time.	• Agree the design with the procurement lead, so that it meets the target standard at level 4. • Keep the records in E34. • Review the first full cycle against M60.	Procurement lead E34, M60 Cycle: As the standard and question state
C61 Put in place S25	**Annual interest declarations** Buying staff do not declare interests. Answered by the respondent.	Everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record. Improving level: Declarations are checked against supplier records, and late or missing declarations are followed up.	• Agree the design with the legal and compliance lead, so that it meets the target standard at level 4. • Keep the records in E35. • Review the first full cycle against M61.	Legal and compliance lead E35, M61 Cycle: As the standard and question state
C62 Put in place S26	**Independent reconciliation** Independent reconciliation: reported as not in place. Answered by the respondent.	Independent reconciliation: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M62.	Finance lead M62 Cycle: Not stated by the method
C63 Put in place S27	**Intermediaries vetted** Intermediaries vetted: reported as not in place. Answered by the respondent.	Intermediaries vetted: in place across everything it should cover. Method detail: L R	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M63.	Procurement lead M63 Cycle: As the standard and question state

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C64 Strengthen S28	**Contract register** Contract register: reported as not in place. Answered by Procurement.	Contract register: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M64.	Procurement lead M64 Cycle: Not stated by the method
C65 Put in place S28	**Variations approved first** Variations approved first: reported as not in place. Answered by the respondent.	Variations approved first: in place across everything it should cover. Method detail: L R	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M65.	Procurement lead M65 Cycle: As the standard and question state
C66 Strengthen S28	**Large variations escalated** Large variations escalated: reported as set out or agreed but not yet working in practice. Answered by Procurement.	Large variations escalated: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M66.	Procurement lead M66 Cycle: Not stated by the method
C67 Strengthen S28	**Written supplier contracts** Written supplier contracts: reported in place only in some areas, cases or periods. Answered by Procurement.	Written supplier contracts: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M67.	Procurement lead M67 Cycle: Not stated by the method
C68 Put in place S29	**Payment file protected** Payment file protected: not in place. Answered by the respondent.	Payment file protected: in place. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M68.	HR and payroll lead M68 Cycle: Not stated by the method
C69 Put in place S30	**Two people pay out cash** Two people pay out cash: reported as not in place. Answered by the respondent.	Two people pay out cash: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M69.	Finance lead M69 Cycle: Not stated by the method
C70 Put in place S31	**Hours approved by supervisor** Hours approved by supervisor: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Hours approved by supervisor: in place across everything it should cover. Method detail: L R	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M70.	HR and payroll lead M70 Cycle: As the standard and question state
C71 Put in place S32	**Claims approved by a manager** Claims approved by a manager: reported in place only in some areas, cases or periods. Answered by the respondent.	Claims approved by a manager: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M71.	Finance lead M71 Cycle: As the standard and question state
C72 Put in place S33	**Broker invoices against attendance** Broker invoices against attendance: reported as not in place. Answered by the respondent.	Broker invoices against attendance: in place across everything it should cover. Method detail: L R C	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M72.	Operations lead M72 Cycle: Not stated by the method
C73 Strengthen S34	**High-risk roles identified** Managers know informally which roles are risky. Answered by HR and payroll.	A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access. Improving level: The list is reviewed when roles change, and it drives screening, access and monitoring. Method detail: C	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E36. • Review the first full cycle against M73.	HR and payroll lead E36, M73 Cycle: Not stated by the method
C74 Strengthen S34	**No conflicting duties when covering** No conflicting duties when covering: reported as set out or agreed but not yet working in practice. Answered by HR and payroll.	No conflicting duties when covering: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M74.	HR and payroll lead M74 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C75 Strengthen S34	**No single point of knowledge** No single point of knowledge: reported as set out or agreed but not yet working in practice. Answered by HR and payroll.	No single point of knowledge: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M75.	HR and payroll lead M75 Cycle: Not stated by the method
C76 Put in place S34	**Block leave required** Most people in sensitive roles take block leave, with someone else doing their work. Answered by the respondent.	Everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved. Improving level: Compliance is monitored, and the work reviewed during leave is checked for irregularities.	• Agree the design with the HR and payroll lead, so that it meets the target standard at level 4. • Keep the records in E37. • Review the first full cycle against M76.	HR and payroll lead E37, M76 Cycle: As the standard and question state
C77 Strengthen S34	**Concerns raised fairly** Concerns raised fairly: reported as not in place. Answered by HR and payroll.	Concerns raised fairly: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M77.	HR and payroll lead M77 Cycle: Not stated by the method
C78 Strengthen S34	**Support for financial pressure** Support for financial pressure: reported as not in place. Answered by HR and payroll.	Support for financial pressure: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M78.	HR and payroll lead M78 Cycle: Not stated by the method
C79 Put in place S35	**Everything supplied is billed** Billing depends on staff remembering. Answered by the respondent.	Every delivery or service is matched to an invoice, and unbilled items are investigated. Improving level: The match is automatic, and unbilled items are reported and reviewed for patterns.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E38. • Review the first full cycle against M79.	Finance lead E38, M79 Cycle: As the standard and question state
C80 Put in place S36	**Customers warned about payment redirection** The bank account appears on invoices, but there is no warning about changes. Answered by the respondent.	Every invoice and statement shows the bank account and states that it will never change by email or message alone. Improving level: Customers are also told through other channels, and attempted invoice interception is tracked and communicated to them.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E39. • Review the first full cycle against M80.	Finance lead E39, M80 Cycle: As the standard and question state
C81 Put in place S37	**Non-standard prices approved** Non-standard prices approved: reported as not in place. Answered by the respondent.	Non-standard prices approved: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M81.	Commercial and customer lead M81 Cycle: Not stated by the method
C82 Put in place S38	**Agent sales verified** Agent sales verified: reported as not in place. Answered by the respondent.	Agent sales verified: in place across everything it should cover. Method detail: L R	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M82.	Commercial and customer lead M82 Cycle: As the standard and question state
C83 Put in place S39	**Register verified physically** The register is never checked against the assets. Answered by the respondent.	Every significant asset is checked against the register at least once a year, and differences are investigated. Improving level: Checks are done by people independent of the custodians, and the results are reported and followed up.	• Agree the design with the operations lead, so that it meets the target standard at level 4. • Keep the records in E40. • Review the first full cycle against M83.	Operations lead E40, M83 Cycle: As the standard and question state
C84 Put in place S40	**Devices wiped before disposal** Devices wiped before disposal: reported in place only in some areas, cases or periods. Answered by the respondent.	Devices wiped before disposal: in place across everything it should cover. Method detail: L R	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M84.	Operations lead M84 Cycle: As the standard and question state

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C85 Put in place S41	**Paid before collection** Payment is confirmed in the bank for larger sales only. Answered by the respondent.	Payment is confirmed on the organisation's own bank statement before any goods are collected. Improving level: The release is approved by someone independent of the sale, and exceptions are reported.	• Agree the design with the finance lead, so that it meets the target standard at level 4. • Keep the records in E41. • Review the first full cycle against M85.	Finance lead E41, M85 Cycle: As the standard and question state
C86 Put in place S42	**Changed collection instructions verified** Changed collection instructions verified: reported in place only in some areas, cases or periods. Answered by the respondent.	Changed collection instructions verified: in place across everything it should cover. Method detail: L R C	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M86.	Operations lead M86 Cycle: Not stated by the method
C87 Put in place S43	**Fuel matched to distance** Fuel purchases are not compared with vehicle use. Answered by the respondent.	Every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated. Improving level: The comparison is automated, exceptions are followed up and repeat offenders are acted on.	• Agree the design with the operations lead, so that it meets the target standard at level 4. • Keep the records in E42. • Review the first full cycle against M87.	Operations lead E42, M87 Cycle: As the standard and question state
C88 Put in place S44	**Help desk resets verified** Most resets need verification through a trusted route, such as the person's manager or a number on file. Answered by the respondent.	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. Improving level: Resets are logged and reviewed, and help desk staff are tested with simulated social engineering calls.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E43. • Review the first full cycle against M88.	IT lead E43, M88 Cycle: As the standard and question state
C89 Put in place S45	**Multi-factor on critical systems** These systems are protected by passwords only. Answered by the respondent.	It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. Improving level: Phishing-resistant methods are used where possible, and coverage is checked regularly.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E44. • Review the first full cycle against M89.	IT lead E44, M89 Cycle: As the standard and question state
C90 Put in place S46	**Access to personal information limited** Access is limited for some systems only. Answered by the respondent.	In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. Improving level: Access is reviewed regularly against roles, and unusual access or exports are alerted and investigated.	• Agree the design with the legal and compliance lead, so that it meets the target standard at level 4. • Keep the records in E45. • Review the first full cycle against M90.	Legal and compliance lead E45, M90 Cycle: As the standard and question state
C91 Put in place S47	**Approval numbers protected** Staff have been told about SIM swaps, but nothing has been changed. Answered by the respondent.	Every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app. Improving level: Protection is checked when numbers or people change, and SMS approvals are being phased out.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E46. • Review the first full cycle against M91.	IT lead E46, M91 Cycle: As the standard and question state
C92 Put in place S48	**Assistant permissions limited** Assistant permissions limited: reported in place only in some areas, cases or periods. Answered by the respondent.	Assistant permissions limited: in place across everything it should cover. Method detail: L R	• Agree the design with the IT lead, so that it meets the target standard. • Review the first full cycle against M92.	IT lead M92 Cycle: As the standard and question state
C93 Put in place S49	**Compromise playbook** There is no plan; each case would be handled from scratch. Answered by the respondent.	A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. Improving level: The plan is tested, and it is updated after each test or incident. Method detail: C	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E47. • Review the first full cycle against M93.	IT lead E47, M93 Cycle: Not stated by the method
C94 Put in place S50	**Domain protected against spoofing** Domain protected against spoofing: partly in place. Answered by the respondent.	Domain protected against spoofing: in place. Method detail: L R C	• Agree the design with the IT lead, so that it meets the target standard. • Review the first full cycle against M94.	IT lead M94 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C95 Strengthen S51	**Data reviewed for unusual patterns** Data reviewed for unusual patterns: reported as not in place. Answered by Risk and investigations.	Data reviewed for unusual patterns: in place across everything it should cover. Method detail: L R C	• Agree the design with the internal audit, so that it meets the target standard. • Review the first full cycle against M95.	Internal audit M95 Cycle: Not stated by the method
C96 Strengthen S51	**Independent review of procurement** Independent review of procurement: partly in place. Answered by Risk and investigations.	Independent review of procurement: in place. Method detail: L R C	• Agree the design with the internal audit, so that it meets the target standard. • Review the first full cycle against M96.	Internal audit M96 Cycle: Not stated by the method
C97 Strengthen S51	**Split orders monitored** Split orders monitored: reported as set out or agreed but not yet working in practice. Answered by Procurement.	Split orders monitored: in place across everything it should cover. Method detail: L R C	• Agree the design with the procurement lead, so that it meets the target standard. • Review the first full cycle against M97.	Procurement lead M97 Cycle: Not stated by the method
C98 Put in place S51	**Senior review of supplier payments** Senior review of supplier payments: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Senior review of supplier payments: in place across everything it should cover. Method detail: L R	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M98.	Finance lead M98 Cycle: Not stated by the method
C99 Put in place S52	**Vouchers controlled in the system** Vouchers controlled in the system: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Vouchers controlled in the system: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M99.	Commercial and customer lead M99 Cycle: Not stated by the method
C100 Put in place S53	**Human review before a customer is blocked** Human review before a customer is blocked: reported in place only in some areas, cases or periods. Answered by the respondent.	Human review before a customer is blocked: in place across everything it should cover. Method detail: L R	• Agree the design with the fraud risk lead, so that it meets the target standard. • Review the first full cycle against M100.	Fraud risk lead M100 Cycle: As the standard and question state
C101 Put in place S54	**Dispatch matched to orders** Dispatch matched to orders: reported as not in place. Answered by the respondent.	Dispatch matched to orders: in place across everything it should cover. Method detail: L R	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M101.	Operations lead M101 Cycle: As the standard and question state
C102 Put in place S55	**Organised theft assessed** Organised theft assessed: reported as not in place. Answered by the respondent.	Organised theft assessed: in place across everything it should cover. Method detail: L R C	• Agree the design with the operations lead, so that it meets the target standard. • Review the first full cycle against M102.	Operations lead M102 Cycle: Not stated by the method
C103 Put in place S56	**Losses tracked and reported** Losses tracked and reported: reported as set out or agreed but not yet working in practice. Answered by the respondent.	Losses tracked and reported: in place across everything it should cover. Method detail: L R C	• Agree the design with the finance lead, so that it meets the target standard. • Review the first full cycle against M103.	Finance lead M103 Cycle: Not stated by the method
C104 Put in place S57	**Staff guided on what not to share** Staff guided on what not to share: reported as not in place. Answered by the respondent.	Staff guided on what not to share: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M104.	Commercial and customer lead M104 Cycle: Not stated by the method
C105 Put in place S58	**Brand impersonation monitored and removed** Brand impersonation monitored and removed: reported as not in place. Answered by the respondent.	Brand impersonation monitored and removed: in place across everything it should cover. Method detail: L R C	• Agree the design with the chief financial officer, so that it meets the target standard. • Review the first full cycle against M105.	Chief financial officer M105 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C106 Strengthen S59	**Training on joining** Training on joining: reported in place only in some areas, cases or periods. Answered by HR and payroll.	Training on joining: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M106.	HR and payroll lead M106 Cycle: Not stated by the method

APPENDIX D

Records management should maintain

The records the method names for each control, for management to keep as the control operates. MK has not requested, received or examined any of them. Independent review of evidence is a separate Advisory service; this report does not perform it.

REF	RECORD	CONTROLS	KEPT BY
E01	The onboarding procedure, completed onboarding files for a sample of new suppliers, exception reports.	C01	Procurement lead
E02	CIPC search results on file, the onboarding form, a sample of supplier records.	C02	Procurement lead
E03	Change records with call-back notes, the procedure, a sample of recent changes.	C06	Finance lead
E04	The procedure wording, training material on cloned voices, simulation or test results.	C07	Finance lead
E05	Account verification results, for example through a bank's account verification service, and the onboarding checklist.	C08	Procurement lead
E06	The delegation of authority, system access lists, a sample of orders and the related payment approvals.	C09	Procurement lead
E07	Purchase orders or approval records dated before the invoice, for a sample of recent purchases.	C10	Procurement lead
E08	Goods received notes, the receiving system, a sample matched to payments.	C11	Operations lead
E09	Payment files showing the order, receipt and invoice, exception reports.	C14	Finance lead
E10	The list of providers with access, access settings, the last access review.	C15	Procurement lead
E11	Bank change records showing how each change was confirmed, the procedure.	C16	HR and payroll lead
E12	Signed payroll review checklists, variance explanations, the approval trail.	C17	HR and payroll lead
E13	Leaver lists reconciled to payroll, the pay run checklist.	C21	HR and payroll lead
E14	Verification service results on employee files, the onboarding checklist.	C22	HR and payroll lead
E15	Verification results from institutions or SAQA, the recruitment checklist.	C23	HR and payroll lead
E16	The remote hiring procedure, identity check results, records of in-person meetings.	C24	HR and payroll lead
E17	A sample of refunds and credit notes with approvals, system workflow settings.	C25	Commercial and customer lead
E18	Refund records showing the payment method used, approved exceptions.	C26	Commercial and customer lead
E19	Change logs for customer records, verification notes, the list of people who can change details.	C33	Commercial and customer lead
E20	Credit approval records, the credit authority matrix, system access to change limits.	C35	Finance lead
E21	Verification records for a sample of applications, the credit procedure.	C36	Finance lead
E22	The unallocated receipts report, debtors reconciliations, follow-up notes.	C40	Finance lead
E23	The claims fraud indicator list, screening results, referrals to investigators.	C42	Commercial and customer lead
E24	Daily reconciliation sheets, the shortages and surpluses log, investigation notes.	C43	Operations lead
E25	Count instructions, count sheets without system quantities, the names of counters and observers.	C45	Finance lead
E26	Approved write-off forms, disposal or destruction certificates, the write-off register.	C47	Finance lead
E27	The email security report showing multi-factor status for every account, including shared mailboxes.	C50	IT lead
E28	The written rule, staff communication, call-back records for a sample of requests.	C51	IT lead
E29	The verification procedure, briefing records for executives, simulation results.	C52	Chief financial officer
E30	Briefing records for executives, the agreed verification method, assistants' instructions.	C53	Chief financial officer
E31	Change records for supplier and executive contact details, how each change was confirmed.	C54	Chief financial officer

REF	RECORD	CONTROLS	KEPT BY
E32	Customer authentication settings, lockout rules, takeover statistics.	C55	IT lead
E33	The breach response procedure, notification templates, records of past notifications.	C56	IT lead
E34	Evaluation scoresheets, the request for quotation or tender with its criteria, committee minutes.	C60	Procurement lead
E35	The declarations register for buying staff, completion records, follow-up of missing declarations.	C61	Legal and compliance lead
E36	The list of high-risk roles and the date it was last reviewed.	C73	HR and payroll lead
E37	The leave policy, leave records for sensitive roles, approved exceptions.	C76	HR and payroll lead
E38	Delivery-to-invoice matching reports, investigation of unbilled items.	C79	Finance lead
E39	Invoice and statement templates, customer communications on payment safety.	C80	Finance lead
E40	Verification results, the list of differences and how each was resolved.	C83	Operations lead
E41	Release records showing payment confirmed on the bank statement.	C85	Finance lead
E42	Fuel exception reports, tracking data comparisons, follow-up notes.	C87	Operations lead
E43	The help desk reset procedure, reset logs, social engineering test results.	C88	IT lead
E44	Multi-factor coverage reports for remote access, cloud and banking systems.	C89	IT lead
E45	Role-based access settings, export restrictions, access reviews.	C90	Legal and compliance lead
E46	The list of numbers used for approvals, SIM-swap protection confirmations, authenticator app rollout.	C91	IT lead
E47	The incident plan for email compromise, its contact list, test or incident records.	C93	IT lead

59 controls have no record named by the method; Appendix C marks them.

APPENDIX E

Action register

Every action in the programme, by phase. Phases follow what must be known and decided first; no dates are set.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A01	2. Decide and assign	Name the executive accountable for ethics, where 1 scheme is open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A02	2. Decide and assign	Name the executive accountable for procurement, where 12 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A03	2. Decide and assign	Name the executive accountable for people, where 11 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A04	2. Decide and assign	Name the executive accountable for customers, where 10 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A05	2. Decide and assign	Name the executive accountable for assets, where 10 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A06	2. Decide and assign	Name the executive accountable for digital channels, where 14 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A07	2. Decide and assign	Decide which of the 58 schemes with a control reported as a gap to address in this cycle, and in what order.	Chief executive	A recorded selection and order, with the reason for each choice.	Every open scheme is either selected, deferred with a reason, or accepted as a risk at the right level.
A08	2. Decide and assign	Approve the target designs for the selected schemes, using the method standards in the control register.	Chief executive	Approved designs, each with an owner and the records it will keep.	Each selected control has an approved design and an owner.
A09	4. Put the remaining controls in place	Put in place: new supplier process (C01).	Procurement lead	C01 operating, keeping the records in E01.	M01 met for one full cycle.
A10	4. Put the remaining controls in place	Put in place: change confirmed with supplier (C06).	Finance lead	C06 operating, keeping the records in E03.	M06 met for one full cycle.
A11	4. Put the remaining controls in place	Put in place: familiar caller still verified (C07).	Finance lead	C07 operating, keeping the records in E04.	M07 met for one full cycle.
A12	4. Put the remaining controls in place	Put in place: bank account verified (C08).	Procurement lead	C08 operating, keeping the records in E05.	M08 met for one full cycle.
A13	4. Put the remaining controls in place	Put in place: orderer is not payment approver (C09).	Procurement lead	C09 operating, keeping the records in E06.	M09 met for one full cycle.
A14	4. Put the remaining controls in place	Put in place: three-way match (C14).	Finance lead	C14 operating, keeping the records in E09.	M14 met for one full cycle.
A15	4. Put the remaining controls in place	Put in place: provider access limited (C15).	Procurement lead	C15 operating, keeping the records in E10.	M15 met for one full cycle.
A16	4. Put the remaining controls in place	Put in place: bank changes confirmed with employee (C16).	HR and payroll lead	C16 operating, keeping the records in E11.	M16 met for one full cycle.
A17	4. Put the remaining controls in place	Put in place: payroll reviewed by another person (C17).	HR and payroll lead	C17 operating, keeping the records in E12.	M17 met for one full cycle.
A18	4. Put the remaining controls in place	Put in place: leavers removed before next run (C21).	HR and payroll lead	C21 operating, keeping the records in E13.	M21 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A19	4. Put the remaining controls in place	Put in place: identity verified (C22).	HR and payroll lead	C22 operating, keeping the records in E14.	M22 met for one full cycle.
A20	4. Put the remaining controls in place	Put in place: remote appointee identity confirmed (C24).	HR and payroll lead	C24 operating, keeping the records in E16.	M24 met for one full cycle.
A21	4. Put the remaining controls in place	Put in place: refunds approved independently (C25).	Commercial and customer lead	C25 operating, keeping the records in E17.	M25 met for one full cycle.
A22	4. Put the remaining controls in place	Put in place: customer detail changes verified (C33).	Commercial and customer lead	C33 operating, keeping the records in E19.	M33 met for one full cycle.
A23	4. Put the remaining controls in place	Put in place: application documents verified (C36).	Finance lead	C36 operating, keeping the records in E21.	M36 met for one full cycle.
A24	4. Put the remaining controls in place	Put in place: fraud indicators screened (C42).	Commercial and customer lead	C42 operating, keeping the records in E23.	M42 met for one full cycle.
A25	4. Put the remaining controls in place	Put in place: daily reconciliation (C43).	Operations lead	C43 operating, keeping the records in E24.	M43 met for one full cycle.
A26	4. Put the remaining controls in place	Put in place: independent blind counts (C45).	Finance lead	C45 operating, keeping the records in E25.	M45 met for one full cycle.
A27	4. Put the remaining controls in place	Put in place: multi-factor on all email (C50).	IT lead	C50 operating, keeping the records in E27.	M50 met for one full cycle.
A28	4. Put the remaining controls in place	Put in place: email never enough on its own (C51).	IT lead	C51 operating, keeping the records in E28.	M51 met for one full cycle.
A29	4. Put the remaining controls in place	Put in place: verification for calls, voice notes and video (C52).	Chief financial officer	C52 operating, keeping the records in E29.	M52 met for one full cycle.
A30	4. Put the remaining controls in place	Put in place: customer logins protected (C55).	IT lead	C55 operating, keeping the records in E32.	M55 met for one full cycle.
A31	4. Put the remaining controls in place	Put in place: compromises reported as POPIA requires (C56).	IT lead	C56 operating, keeping the records in E33.	M56 met for one full cycle.
A32	4. Put the remaining controls in place	Put in place: recipients checked for links (C58).	Ethics lead	C58 operating, with a record of each case it covers.	M58 met for one full cycle.
A33	4. Put the remaining controls in place	Put in place: evaluation against set criteria (C60).	Procurement lead	C60 operating, keeping the records in E34.	M60 met for one full cycle.
A34	4. Put the remaining controls in place	Put in place: annual interest declarations (C61).	Legal and compliance lead	C61 operating, keeping the records in E35.	M61 met for one full cycle.
A35	4. Put the remaining controls in place	Put in place: independent reconciliation (C62).	Finance lead	C62 operating, with a record of each case it covers.	M62 met for one full cycle.
A36	4. Put the remaining controls in place	Put in place: intermediaries vetted (C63).	Procurement lead	C63 operating, with a record of each case it covers.	M63 met for one full cycle.
A37	4. Put the remaining controls in place	Put in place: variations approved first (C65).	Procurement lead	C65 operating, with a record of each case it covers.	M65 met for one full cycle.
A38	4. Put the remaining controls in place	Put in place: payment file protected (C68).	HR and payroll lead	C68 operating, with a record of each case it covers.	M68 met for one full cycle.
A39	4. Put the remaining controls in place	Put in place: two people pay out cash (C69).	Finance lead	C69 operating, with a record of each case it covers.	M69 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A40	4. Put the remaining controls in place	Put in place: hours approved by supervisor (C70).	HR and payroll lead	C70 operating, with a record of each case it covers.	M70 met for one full cycle.
A41	4. Put the remaining controls in place	Put in place: claims approved by a manager (C71).	Finance lead	C71 operating, with a record of each case it covers.	M71 met for one full cycle.
A42	4. Put the remaining controls in place	Put in place: broker invoices against attendance (C72).	Operations lead	C72 operating, with a record of each case it covers.	M72 met for one full cycle.
A43	4. Put the remaining controls in place	Put in place: block leave required (C76).	HR and payroll lead	C76 operating, keeping the records in E37.	M76 met for one full cycle.
A44	4. Put the remaining controls in place	Put in place: everything supplied is billed (C79).	Finance lead	C79 operating, keeping the records in E38.	M79 met for one full cycle.
A45	4. Put the remaining controls in place	Put in place: customers warned about payment redirection (C80).	Finance lead	C80 operating, keeping the records in E39.	M80 met for one full cycle.
A46	4. Put the remaining controls in place	Put in place: non-standard prices approved (C81).	Commercial and customer lead	C81 operating, with a record of each case it covers.	M81 met for one full cycle.
A47	4. Put the remaining controls in place	Put in place: agent sales verified (C82).	Commercial and customer lead	C82 operating, with a record of each case it covers.	M82 met for one full cycle.
A48	4. Put the remaining controls in place	Put in place: register verified physically (C83).	Operations lead	C83 operating, keeping the records in E40.	M83 met for one full cycle.
A49	4. Put the remaining controls in place	Put in place: devices wiped before disposal (C84).	Operations lead	C84 operating, with a record of each case it covers.	M84 met for one full cycle.
A50	4. Put the remaining controls in place	Put in place: paid before collection (C85).	Finance lead	C85 operating, keeping the records in E41.	M85 met for one full cycle.
A51	4. Put the remaining controls in place	Put in place: changed collection instructions verified (C86).	Operations lead	C86 operating, with a record of each case it covers.	M86 met for one full cycle.
A52	4. Put the remaining controls in place	Put in place: fuel matched to distance (C87).	Operations lead	C87 operating, keeping the records in E42.	M87 met for one full cycle.
A53	4. Put the remaining controls in place	Put in place: help desk resets verified (C88).	IT lead	C88 operating, keeping the records in E43.	M88 met for one full cycle.
A54	4. Put the remaining controls in place	Put in place: multi-factor on critical systems (C89).	IT lead	C89 operating, keeping the records in E44.	M89 met for one full cycle.
A55	4. Put the remaining controls in place	Put in place: access to personal information limited (C90).	Legal and compliance lead	C90 operating, keeping the records in E45.	M90 met for one full cycle.
A56	4. Put the remaining controls in place	Put in place: approval numbers protected (C91).	IT lead	C91 operating, keeping the records in E46.	M91 met for one full cycle.
A57	4. Put the remaining controls in place	Put in place: assistant permissions limited (C92).	IT lead	C92 operating, with a record of each case it covers.	M92 met for one full cycle.
A58	4. Put the remaining controls in place	Put in place: compromise playbook (C93).	IT lead	C93 operating, keeping the records in E47.	M93 met for one full cycle.
A59	4. Put the remaining controls in place	Put in place: domain protected against spoofing (C94).	IT lead	C94 operating, with a record of each case it covers.	M94 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A60	4. Put the remaining controls in place	Put in place: senior review of supplier payments (C98).	Finance lead	C98 operating, with a record of each case it covers.	M98 met for one full cycle.
A61	4. Put the remaining controls in place	Put in place: vouchers controlled in the system (C99).	Commercial and customer lead	C99 operating, with a record of each case it covers.	M99 met for one full cycle.
A62	4. Put the remaining controls in place	Put in place: human review before a customer is blocked (C100).	Fraud risk lead	C100 operating, with a record of each case it covers.	M100 met for one full cycle.
A63	4. Put the remaining controls in place	Put in place: dispatch matched to orders (C101).	Operations lead	C101 operating, with a record of each case it covers.	M101 met for one full cycle.
A64	4. Put the remaining controls in place	Put in place: organised theft assessed (C102).	Operations lead	C102 operating, with a record of each case it covers.	M102 met for one full cycle.
A65	4. Put the remaining controls in place	Put in place: losses tracked and reported (C103).	Finance lead	C103 operating, with a record of each case it covers.	M103 met for one full cycle.
A66	4. Put the remaining controls in place	Put in place: staff guided on what not to share (C104).	Commercial and customer lead	C104 operating, with a record of each case it covers.	M104 met for one full cycle.
A67	4. Put the remaining controls in place	Put in place: brand impersonation monitored and removed (C105).	Chief financial officer	C105 operating, with a record of each case it covers.	M105 met for one full cycle.
A68	5. Strengthen further defences	Strengthen: directors identified (C02).	Procurement lead	C02 operating, keeping the records in E02.	M02 met for one full cycle.
A69	5. Strengthen further defences	Strengthen: directors compared with staff (C03).	Procurement lead	C03 operating, with a record of each case it covers.	M03 met for one full cycle.
A70	5. Strengthen further defences	Strengthen: suppliers re-checked (C04).	Procurement lead	C04 operating, with a record of each case it covers.	M04 met for one full cycle.
A71	5. Strengthen further defences	Strengthen: dormant suppliers deactivated (C05).	Procurement lead	C05 operating, with a record of each case it covers.	M05 met for one full cycle.
A72	5. Strengthen further defences	Strengthen: approved order before commitment (C10).	Procurement lead	C10 operating, keeping the records in E07.	M10 met for one full cycle.
A73	5. Strengthen further defences	Strengthen: receipt recorded before payment (C11).	Operations lead	C11 operating, keeping the records in E08.	M11 met for one full cycle.
A74	5. Strengthen further defences	Strengthen: quantities checked (C12).	Operations lead	C12 operating, with a record of each case it covers.	M12 met for one full cycle.
A75	5. Strengthen further defences	Strengthen: services confirmed (C13).	Operations lead	C13 operating, with a record of each case it covers.	M13 met for one full cycle.
A76	5. Strengthen further defences	Strengthen: headcount verification done (C18).	HR and payroll lead	C18 operating, with a record of each case it covers.	M18 met for one full cycle.
A77	5. Strengthen further defences	Strengthen: payroll data analysed (C19).	HR and payroll lead	C19 operating, with a record of each case it covers.	M19 met for one full cycle.
A78	5. Strengthen further defences	Strengthen: independent review of payroll (C20).	HR and payroll lead	C20 operating, with a record of each case it covers.	M20 met for one full cycle.
A79	5. Strengthen further defences	Strengthen: qualifications verified (C23).	HR and payroll lead	C23 operating, keeping the records in E15.	M23 met for one full cycle.
A80	5. Strengthen further defences	Strengthen: refunds to the original source (C26).	Commercial and customer lead	C26 operating, keeping the records in E18.	M26 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A81	5. Strengthen further defences	Strengthen: returns received before credit (C27).	Commercial and customer lead	C27 operating, with a record of each case it covers.	M27 met for one full cycle.
A82	5. Strengthen further defences	Strengthen: refund patterns reviewed (C28).	Commercial and customer lead	C28 operating, with a record of each case it covers.	M28 met for one full cycle.
A83	5. Strengthen further defences	Strengthen: post-period reversals reviewed (C29).	Commercial and customer lead	C29 operating, with a record of each case it covers.	M29 met for one full cycle.
A84	5. Strengthen further defences	Strengthen: claim evidence checked for AI (C30).	Commercial and customer lead	C30 operating, with a record of each case it covers.	M30 met for one full cycle.
A85	5. Strengthen further defences	Strengthen: defined onboarding (C31).	Commercial and customer lead	C31 operating, with a record of each case it covers.	M31 met for one full cycle.
A86	5. Strengthen further defences	Strengthen: business customers verified (C32).	Commercial and customer lead	C32 operating, with a record of each case it covers.	M32 met for one full cycle.
A87	5. Strengthen further defences	Strengthen: shared details flagged (C34).	Commercial and customer lead	C34 operating, with a record of each case it covers.	M34 met for one full cycle.
A88	5. Strengthen further defences	Strengthen: credit approved independently (C35).	Finance lead	C35 operating, keeping the records in E20.	M35 met for one full cycle.
A89	5. Strengthen further defences	Strengthen: bureau and fraud database checks (C37).	Finance lead	C37 operating, with a record of each case it covers.	M37 met for one full cycle.
A90	5. Strengthen further defences	Strengthen: early defaults investigated (C38).	Finance lead	C38 operating, with a record of each case it covers.	M38 met for one full cycle.
A91	5. Strengthen further defences	Strengthen: limit and terms changes approved (C39).	Finance lead	C39 operating, with a record of each case it covers.	M39 met for one full cycle.
A92	5. Strengthen further defences	Strengthen: payments matched to invoices (C40).	Finance lead	C40 operating, keeping the records in E22.	M40 met for one full cycle.
A93	5. Strengthen further defences	Strengthen: statements sent from the system (C41).	Finance lead	C41 operating, with a record of each case it covers.	M41 met for one full cycle.
A94	5. Strengthen further defences	Strengthen: full counts (C44).	Finance lead	C44 operating, with a record of each case it covers.	M44 met for one full cycle.
A95	5. Strengthen further defences	Strengthen: differences explained before adjusting (C46).	Finance lead	C46 operating, with a record of each case it covers.	M46 met for one full cycle.
A96	5. Strengthen further defences	Strengthen: write-offs approved and supervised (C47).	Finance lead	C47 operating, keeping the records in E26.	M47 met for one full cycle.
A97	5. Strengthen further defences	Strengthen: shrinkage tracked (C48).	Finance lead	C48 operating, with a record of each case it covers.	M48 met for one full cycle.
A98	5. Strengthen further defences	Strengthen: how stock is recorded (C49).	Operations lead	C49 operating, with a record of each case it covers.	M49 met for one full cycle.
A99	5. Strengthen further defences	Strengthen: executives and their teams prepared (C53).	Chief financial officer	C53 operating, keeping the records in E30.	M53 met for one full cycle.
A100	5. Strengthen further defences	Strengthen: changes to call-back details verified (C54).	Chief financial officer	C54 operating, keeping the records in E31.	M54 met for one full cycle.
A101	5. Strengthen further defences	Strengthen: affected people warned (C57).	Legal and compliance lead	C57 operating, with a record of each case it covers.	M57 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A102	5. Strengthen further defences	Strengthen: quote and tender thresholds (C59).	Procurement lead	C59 operating, with a record of each case it covers.	M59 met for one full cycle.
A103	5. Strengthen further defences	Strengthen: contract register (C64).	Procurement lead	C64 operating, with a record of each case it covers.	M64 met for one full cycle.
A104	5. Strengthen further defences	Strengthen: large variations escalated (C66).	Procurement lead	C66 operating, with a record of each case it covers.	M66 met for one full cycle.
A105	5. Strengthen further defences	Strengthen: written supplier contracts (C67).	Procurement lead	C67 operating, with a record of each case it covers.	M67 met for one full cycle.
A106	5. Strengthen further defences	Strengthen: high-risk roles identified (C73).	HR and payroll lead	C73 operating, keeping the records in E36.	M73 met for one full cycle.
A107	5. Strengthen further defences	Strengthen: no conflicting duties when covering (C74).	HR and payroll lead	C74 operating, with a record of each case it covers.	M74 met for one full cycle.
A108	5. Strengthen further defences	Strengthen: no single point of knowledge (C75).	HR and payroll lead	C75 operating, with a record of each case it covers.	M75 met for one full cycle.
A109	5. Strengthen further defences	Strengthen: concerns raised fairly (C77).	HR and payroll lead	C77 operating, with a record of each case it covers.	M77 met for one full cycle.
A110	5. Strengthen further defences	Strengthen: support for financial pressure (C78).	HR and payroll lead	C78 operating, with a record of each case it covers.	M78 met for one full cycle.
A111	5. Strengthen further defences	Strengthen: data reviewed for unusual patterns (C95).	Internal audit	C95 operating, with a record of each case it covers.	M95 met for one full cycle.
A112	5. Strengthen further defences	Strengthen: independent review of procurement (C96).	Internal audit	C96 operating, with a record of each case it covers.	M96 met for one full cycle.
A113	5. Strengthen further defences	Strengthen: split orders monitored (C97).	Procurement lead	C97 operating, with a record of each case it covers.	M97 met for one full cycle.
A114	5. Strengthen further defences	Strengthen: training on joining (C106).	HR and payroll lead	C106 operating, with a record of each case it covers.	M106 met for one full cycle.
A115	6. Operate, measure and report	Run the 17 controls owned by the procurement lead through a full cycle and check each against its success measure.	Procurement lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A116	6. Operate, measure and report	Run the 23 controls owned by the finance lead through a full cycle and check each against its success measure.	Finance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A117	6. Operate, measure and report	Run the 12 controls owned by the operations lead through a full cycle and check each against its success measure.	Operations lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A118	6. Operate, measure and report	Run the 18 controls owned by the HR and payroll lead through a full cycle and check each against its success measure.	HR and payroll lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A119	6. Operate, measure and report	Run the 15 controls owned by the commercial and customer lead through a full cycle and check each against its success measure.	Commercial and customer lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A120	6. Operate, measure and report	Run the 10 controls owned by the IT lead through a full cycle and check each against its success measure.	IT lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A121	6. Operate, measure and report	Run the 4 controls owned by the chief financial officer through a full cycle and check each against its success measure.	Chief financial officer	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A122	6. Operate, measure and report	Run the 3 controls owned by the legal and compliance lead through a full cycle and check each against its success measure.	Legal and compliance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A123	6. Operate, measure and report	Run the 1 control owned by the ethics lead through a full cycle and check each against its success measure.	Ethics lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A124	6. Operate, measure and report	Run the 2 controls owned by the internal audit through a full cycle and check each against its success measure.	Internal audit	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A125	6. Operate, measure and report	Run the 1 control owned by the fraud risk lead through a full cycle and check each against its success measure.	Fraud risk lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A126	6. Operate, measure and report	Report the status of every open and unresolved scheme to the board or its audit committee at each of its meetings until each is closed, deferred with a reason or accepted.	Chief executive	A one-page status: scheme, owner, controls in place, controls outstanding, next step.	The status is received and minuted at each meeting.

APPENDIX F

Measurement register

One success measure for each control, in the method's terms.

REF	MEASURE	CONTROL	OWNER
M01	Records for the period show that every new supplier goes through a defined process, with set checks and an approval, before it can be paid.	C01	Procurement lead
M02	Records for the period show that directors and owners, including those behind holding companies, are identified for every new supplier from an independent source.	C02	Procurement lead
M03	Records for the period show this practice applied to every case in scope: directors compared with staff.	C03	Procurement lead
M04	Records for the period show this practice applied to every case in scope: suppliers re-checked.	C04	Procurement lead
M05	Records for the period show this practice applied to every case in scope: dormant suppliers deactivated.	C05	Procurement lead
M06	Records for the period show that every change is confirmed with the supplier using contact details already on file before it takes effect.	C06	Finance lead
M07	Records for the period show that the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.	C07	Finance lead
M08	Records for the period show that every new supplier's account is verified through a bank or third-party service before the first payment.	C08	Procurement lead
M09	Records for the period show that the duties are always separated, or any exception is approved and recorded.	C09	Procurement lead
M10	Records for the period show that every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded.	C10	Procurement lead
M11	Records for the period show that receipt is always recorded before the related invoice is paid.	C11	Operations lead
M12	Records for the period show this practice applied to every case in scope: quantities checked.	C12	Operations lead
M13	Records for the period show this practice applied to every case in scope: services confirmed.	C13	Operations lead
M14	Records for the period show that every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.	C14	Finance lead
M15	Records for the period show that every provider's access is limited to what the service needs, logged and reviewed at least once a year.	C15	Procurement lead
M16	Records for the period show that every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.	C16	HR and payroll lead
M17	Records for the period show that every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded.	C17	HR and payroll lead
M18	The position the method treats as in place holds for the period: headcount verification done: in place.	C18	HR and payroll lead
M19	Records for the period show this practice applied to every case in scope: payroll data analysed.	C19	HR and payroll lead
M20	The position the method treats as in place holds for the period: independent review of payroll: in place.	C20	HR and payroll lead
M21	Records for the period show that every leaver is confirmed as removed before the next pay run, using the HR leaver list.	C21	HR and payroll lead
M22	Records for the period show that every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start.	C22	HR and payroll lead
M23	Records for the period show that every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final.	C23	HR and payroll lead
M24	Records for the period show that every remote appointee is confirmed through an in-person meeting or an identity check designed to resist replayed and injected video before access and pay are set up, and failed checks are reviewed by a person.	C24	HR and payroll lead
M25	Records for the period show that every refund and credit note is approved by someone other than the person who processes it.	C25	Commercial and customer lead
M26	Records for the period show that every refund goes to the original payment method or to a customer account verified before payment.	C26	Commercial and customer lead

REF	MEASURE	CONTROL	OWNER
M27	Records for the period show this practice applied to every case in scope: returns received before credit.	C27	Commercial and customer lead
M28	Records for the period show this practice applied to every case in scope: refund patterns reviewed.	C28	Commercial and customer lead
M29	Records for the period show this practice applied to every case in scope: post-period reversals reviewed.	C29	Commercial and customer lead
M30	Records for the period show this practice applied to every case in scope: claim evidence checked for AI.	C30	Commercial and customer lead
M31	Records for the period show this practice applied to every case in scope: defined onboarding.	C31	Commercial and customer lead
M32	Records for the period show this practice applied to every case in scope: business customers verified.	C32	Commercial and customer lead
M33	Records for the period show that every change to refund accounts, addresses and contact numbers is verified with the customer through known details and made by someone outside sales.	C33	Commercial and customer lead
M34	Records for the period show this practice applied to every case in scope: shared details flagged.	C34	Commercial and customer lead
M35	Records for the period show that every credit limit is approved by someone other than the salesperson, within set authority levels.	C35	Finance lead
M36	Records for the period show that the key information in every application is verified with the source, such as the employer, the bank or a verification service, before credit is approved.	C36	Finance lead
M37	Records for the period show this practice applied to every case in scope: bureau and fraud database checks.	C37	Finance lead
M38	Records for the period show this practice applied to every case in scope: early defaults investigated.	C38	Finance lead
M39	Records for the period show this practice applied to every case in scope: limit and terms changes approved.	C39	Finance lead
M40	Records for the period show that every payment is matched to the right invoice, and unallocated receipts and misallocations are investigated and cleared promptly.	C40	Finance lead
M41	Records for the period show this practice applied to every case in scope: statements sent from the system.	C41	Finance lead
M42	Records for the period show that every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred.	C42	Commercial and customer lead
M43	Records for the period show that takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated.	C43	Operations lead
M44	Records for the period show this practice applied to every case in scope: full counts.	C44	Finance lead
M45	Records for the period show that every count is carried out or observed by people independent of the stores team, counting without sight of system quantities.	C45	Finance lead
M46	Records for the period show this practice applied to every case in scope: differences explained before adjusting.	C46	Finance lead
M47	Records for the period show that every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record.	C47	Finance lead
M48	Records for the period show this practice applied to every case in scope: shrinkage tracked.	C48	Finance lead
M49	The position the method treats as in place holds for the period: how stock is recorded: in an inventory or ERP system or in spreadsheets or manual records.	C49	Operations lead
M50	Records for the period show that multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	C50	IT lead
M51	Records for the period show that an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	C51	IT lead
M52	Records for the period show that an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.	C52	Chief financial officer
M53	Records for the period show that every executive with a public voice or face has been briefed and has an agreed verification method that their assistants and finance teams use.	C53	Chief financial officer
M54	Records for the period show that every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used.	C54	Chief financial officer
M55	Records for the period show that customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts.	C55	IT lead

REF	MEASURE	CONTROL	OWNER
M56	Records for the period show that a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	C56	IT lead
M57	Records for the period show this practice applied to every case in scope: affected people warned.	C57	Legal and compliance lead
M58	Records for the period show this practice applied to every case in scope: recipients checked for links.	C58	Ethics lead
M59	Records for the period show this practice applied to every case in scope: quote and tender thresholds.	C59	Procurement lead
M60	Records for the period show that every competitive purchase is evaluated by more than one person against criteria set before bids are received, and scores are recorded.	C60	Procurement lead
M61	Records for the period show that everyone involved in buying declares interests each year and when circumstances change, and declarations are kept on record.	C61	Legal and compliance lead
M62	Records for the period show this practice applied to every case in scope: independent reconciliation.	C62	Finance lead
M63	Records for the period show this practice applied to every case in scope: intermediaries vetted.	C63	Procurement lead
M64	Records for the period show this practice applied to every case in scope: contract register.	C64	Procurement lead
M65	Records for the period show this practice applied to every case in scope: variations approved first.	C65	Procurement lead
M66	Records for the period show this practice applied to every case in scope: large variations escalated.	C66	Procurement lead
M67	Records for the period show this practice applied to every case in scope: written supplier contracts.	C67	Procurement lead
M68	The position the method treats as in place holds for the period: payment file protected: in place.	C68	HR and payroll lead
M69	Records for the period show this practice applied to every case in scope: two people pay out cash.	C69	Finance lead
M70	Records for the period show this practice applied to every case in scope: hours approved by supervisor.	C70	HR and payroll lead
M71	Records for the period show this practice applied to every case in scope: claims approved by a manager.	C71	Finance lead
M72	Records for the period show this practice applied to every case in scope: broker invoices against attendance.	C72	Operations lead
M73	Records for the period show that a maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.	C73	HR and payroll lead
M74	Records for the period show this practice applied to every case in scope: no conflicting duties when covering.	C74	HR and payroll lead
M75	Records for the period show this practice applied to every case in scope: no single point of knowledge.	C75	HR and payroll lead
M76	Records for the period show that everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved.	C76	HR and payroll lead
M77	Records for the period show this practice applied to every case in scope: concerns raised fairly.	C77	HR and payroll lead
M78	Records for the period show this practice applied to every case in scope: support for financial pressure.	C78	HR and payroll lead
M79	Records for the period show that every delivery or service is matched to an invoice, and unbilled items are investigated.	C79	Finance lead
M80	Records for the period show that every invoice and statement shows the bank account and states that it will never change by email or message alone.	C80	Finance lead
M81	Records for the period show this practice applied to every case in scope: non-standard prices approved.	C81	Commercial and customer lead
M82	Records for the period show this practice applied to every case in scope: agent sales verified.	C82	Commercial and customer lead
M83	Records for the period show that every significant asset is checked against the register at least once a year, and differences are investigated.	C83	Operations lead
M84	Records for the period show this practice applied to every case in scope: devices wiped before disposal.	C84	Operations lead
M85	Records for the period show that payment is confirmed on the organisation's own bank statement before any goods are collected.	C85	Finance lead
M86	Records for the period show this practice applied to every case in scope: changed collection instructions verified.	C86	Operations lead
M87	Records for the period show that every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated.	C87	Operations lead

REF	MEASURE	CONTROL	OWNER
M88	Records for the period show that every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	C88	IT lead
M89	Records for the period show that it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	C89	IT lead
M90	Records for the period show that in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	C90	Legal and compliance lead
M91	Records for the period show that every number used to approve payments or reset access has a network SIM-swap lock or has been replaced by an authenticator app.	C91	IT lead
M92	Records for the period show this practice applied to every case in scope: assistant permissions limited.	C92	IT lead
M93	Records for the period show that a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	C93	IT lead
M94	The position the method treats as in place holds for the period: domain protected against spoofing: in place.	C94	IT lead
M95	Records for the period show this practice applied to every case in scope: data reviewed for unusual patterns.	C95	Internal audit
M96	The position the method treats as in place holds for the period: independent review of procurement: in place.	C96	Internal audit
M97	Records for the period show this practice applied to every case in scope: split orders monitored.	C97	Procurement lead
M98	Records for the period show this practice applied to every case in scope: senior review of supplier payments.	C98	Finance lead
M99	Records for the period show this practice applied to every case in scope: vouchers controlled in the system.	C99	Commercial and customer lead
M100	Records for the period show this practice applied to every case in scope: human review before a customer is blocked.	C100	Fraud risk lead
M101	Records for the period show this practice applied to every case in scope: dispatch matched to orders.	C101	Operations lead
M102	Records for the period show this practice applied to every case in scope: organised theft assessed.	C102	Operations lead
M103	Records for the period show this practice applied to every case in scope: losses tracked and reported.	C103	Finance lead
M104	Records for the period show this practice applied to every case in scope: staff guided on what not to share.	C104	Commercial and customer lead
M105	Records for the period show this practice applied to every case in scope: brand impersonation monitored and removed.	C105	Chief financial officer
M106	Records for the period show this practice applied to every case in scope: training on joining.	C106	HR and payroll lead

APPENDIX G

Answer relationships

For each control reported fully in place, every practice of the same scheme reported weaker, not yet used or outstanding, and how the two answers relate. Only answers that cannot both be right, or a control relying on a weaker practice, leave the control unresolved. A further defence reported weaker does not change the answer given for the control; the reason for each classification is given.

SCHEME	CONTROL REPORTED IN PLACE	PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S59	**Code accessible to staff**	Training on joining: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER Reviewed pair	Fraud and ethics training at joining is distinct from explaining conduct standards where employees work; induction is only one of the places Code accessible to staff names.

APPENDIX H

Outstanding information

Every question asked and not answered. A declined question, a question answered "I don't know" and a question still waiting are all outstanding; none is treated as answered.

No answer is outstanding.

APPENDIX I

Roles used in this report

Each consolidated role and the method's own suggested owners behind it.

ROLE IN THIS REPORT	METHOD WORDING
Chief financial officer	CFO and head of IT together
Commercial and customer lead	Channel or sales manager; Claims manager; Communications or marketing manager; Customer onboarding or operations manager; Customer service or finance manager; Marketing manager; Sales or commercial manager
Ethics lead	CSI or sustainability lead
Finance lead	Billing or debtors manager; Credit manager; Creditors manager; Creditors manager or financial controller; Financial controller; Financial controller or internal audit; Financial controller, with the asset owner
Fraud risk lead	Fraud or risk lead
HR and payroll lead	HR manager; HR manager, with the head of IT; HR or learning lead; HR or payroll manager; HR or recruitment manager; Payroll manager; Payroll manager or financial controller; Payroll manager or internal audit
Internal audit	Internal audit or financial controller
IT lead	Head of IT or IT provider; Head of IT or information security; Head of IT or the person responsible for AI tools; Head of IT, with finance; Head of digital channels
Legal and compliance lead	Compliance lead or HR; Information officer (POPIA)
Operations lead	Asset or facilities manager; Fleet manager; Logistics manager; Operations manager; Operations or financial manager; Security manager; Store, branch or cash office manager; Stores or operations manager; Warehouse or stores manager
Procurement lead	Contract manager; Head of procurement or CFO; Head of procurement or bid committee secretary; Head of procurement, with the business owner of each relationship; Procurement manager; Procurement or creditors manager; Procurement or the finance manager